

Amenaza interna centrada en el humano: Análisis de *logs* corporativos y perfilado conductual



Universitat Oberta
de Catalunya

Antonio Barrera Mora

Área 2: Natural Language Processing,
Cibersecurity and Visual Analytics
(A2. NPL&VA)

Máster en Ciencia de Datos

Director del TF:

Blas Torregrosa García

Directora de la PRA:

Esther Ibáñez

26 de mayo de 2026



Esta obra esta sujeta a una licencia de Reconocimiento-NoComercial
<https://creativecommons.org/licenses/by-nc/3.0/es/>

Ficha Del Trabajo Final

Título del trabajo:	Amenaza interna centrada en el humano: Análisis de <i>logs</i> corporativos y perfilado conductual
Nombre del autor/a:	Antonio Barrera Mora
Director del TF:	Blas Torregrosa García
Directora de la PRA:	Esther Ibáñez
Fecha de entrega:	26 de mayo de 2026
Titulación o programa:	Máster en Ciencia de Datos
Área del trabajo final:	Área 2: Natural Language Processing, Cybersecurity and Visual Analytics (A2. NPL&VA)
Idioma del trabajo:	Castellano
Palabras clave:	Insider Threat, UEBA, NLP, Machine Learning, Criminología Corporativa, Dataset CERT

Resumen del trabajo

La detección de la amenaza interna (*insider threat*) constituye uno de los mayores desafíos en la ciberseguridad corporativa. Las soluciones tradicionales basadas en reglas y técnicas estáticas, presentan limitaciones severas al identificar actores maliciosos que poseen credenciales legítimas. En este trabajo se presenta el desarrollo de un **prototipo académico** fundamentado en un enfoque híbrido centrado en el ser humano. Utilizando el conjunto de datos CERT r4.2, el proyecto integra la extracción de características técnicas (registros de actividad y navegación web) con el análisis de indicadores conductuales y de estado psicológico dinámica mediante el procesamiento de lenguaje natural (NLP) aplicado a comunicaciones escritas. Se evalúan y comparan modelos de aprendizaje automático no supervisado (e.g., *Isolation Forest*), incorporando técnicas de explicabilidad (SHAP) para la interpretación del riesgo. Los resultados sugieren que la convergencia interdisciplinar entre la criminología corporativa, la psicología forense y la ciencia de datos permite modelar la deriva conductual, aportando una mitigación proactiva frente a escenarios complejos de amenaza interna.

Abstract

Detecting insider threats constitutes one of the most critical challenges in corporate cybersecurity. Traditional solutions, rooted in static technical rules, exhibit severe limitations in identifying malicious actors who possess legitimate credentials. This paper presents the development of an **academic prototype** based on a human-centered hybrid approach. Using the CERT r4.2 dataset, the project integrates the extraction of technical features (activity and web navigation logs) with the analysis of behavioral indicators and dynamic psychological states through Natural Language Processing (NLP) applied to written communications. Unsupervised machine learning models (e.g., Isolation Forest) are evaluated and compared, incorporating explainability techniques (SHAP) for risk interpretation. The results suggest that the interdisciplinary convergence of corporate criminology, forensic psychology, and data science enables the modeling of behavioral drift, providing a proactive mitigation framework against complex insider threat scenarios.

Índice general

1. Introducción	9
1.1. Contexto y justificación del trabajo	9
1.2. Motivación personal	10
1.3. Objetivos del trabajo	10
1.4. Preguntas de investigación e hipótesis	11
1.5. Impacto en sostenibilidad, ético-social y de diversidad	11
1.6. Enfoque y método seguido	12
1.7. Planificación del trabajo	13
1.7.1. Gestión de Riesgos:	13
1.8. Declaración sobre el uso de inteligencia artificial generativa	13
2. Estado del arte	15
2.1. Criminología corporativa y la psicología del atacante interno	15
2.2. Análisis de Comportamiento de Usuarios y Entidades (UEBA)	16
2.3. Procesamiento de Lenguaje Natural (NLP) en ciberseguridad	17
2.4. Justificación y aportación diferencial de la propuesta	17
3. Materiales y métodos	20
3.1. Diseño y desarrollo del trabajo	20
3.2. Metodología y toma de decisiones	21
3.2.1. Selección y justificación de hiperparámetros	21
3.3. Limitaciones del conjunto de datos y validez ecológica	22
3.4. Productos obtenidos	24
4. Resultados	26
5. Discusión	30
5.1. El sentimiento como confirmador, no como activador (PIE 1)	30
5.2. Limitaciones del AUC como métrica principal (PIE 2)	31
5.3. Complementariedad algorítmica y sistema de ensamblaje (PIE 3)	31
5.4. Validación XAI del modelo criminológico CPIR (PIE 4)	32
5.5. Marco ético, legal y protocolo de actuación	32
5.6. El rol del <i>Big Five</i> en el modelo	34
5.7. Consideraciones éticas y legales del uso de psicometría organizacional	34

6. Conclusiones y trabajos futuros	36
6.1. Conclusiones	36
6.2. Logro de los objetivos	37
6.3. Análisis de planificación y metodología	37
6.4. Impactos éticos, sociales y normativos	37
6.5. Líneas de futuro	38
7. Glosario	42
8. Bibliografía	51

Índice de figuras

- 4.1. Curva ROC del Autoencoder ($AUC = 0.551$). La variación respecto al AUC del *Isolation Forest* (0.629) ilustra el efecto que supone para la métrica global la concentración del error de reconstrucción en el umbral crítico superior. 27
- 4.2. Gráfico de cascada SHAP del usuario MPM0220. Las barras en tonalidad roja indican variables que empujan la puntuación de anomalía hacia un mayor índice de riesgo, mientras que las azules la orientan hacia la normalidad operativa. La variable de mayor contribución corresponde a la actividad fuera de horario, seguida de la hiperactividad en inicios de sesión y el uso de dispositivos USB. . . 29

Índice de cuadros

4.1. Descomposición SHAP del evento crítico del usuario confirmado MPM0220 (2010-10-04). El valor base del modelo de referencia se sitúa en $E[f(X)] = 12,306$, resultando una predicción final de $f(x) = 4,369$	28
--	----

Capítulo 1

Introducción

El impacto económico y operativo de los incidentes provocados por amenazas internas (*insider threats*) ha experimentado un crecimiento notable en los últimos años, afectando de manera transversal a la propiedad intelectual, la reputación institucional y el cumplimiento normativo de las organizaciones. Históricamente, los enfoques convencionales de ciberseguridad han priorizado la defensa del perímetro frente a vectores de ataque externos, o bien se han limitado a la auditoría técnica mediante la monitorización de variables de red aisladas (direcciones IP o puertos de comunicación).

Sin embargo, los actores internos corporativos (saboteadores o empleados que 'exfiltran' información motivados por el descontento o la coacción) se configuran como elementos humanos dentro de un sistema complejo. Como tales, suelen manifestar una deriva conductual y variaciones psicológicas potencialmente detectables de forma previa a la ejecución del acto delictivo.

Esta necesidad de evolucionar desde la auditoría estática hacia modelos analíticos centrados en el comportamiento responde a un desafío tanto técnico como financiero. De acuerdo con el informe *Cost of Insider Threats* (Sulli, 2023), el coste medio anual derivado de este tipo de incidentes asciende a 15,4 millones de dólares por organización; un escenario agravado por la recurrente ineficacia de los sistemas de detección puramente volumétricos frente a anomalías sutiles de perfil conductual.

1.1. Contexto y justificación del trabajo

La relevancia de este trabajo radica en su enfoque multidisciplinar, conocido en el sector como **Análisis del Comportamiento de Usuarios y Entidades** (UEBA, por sus siglas en inglés). En lugar de investigar únicamente firmas de código malicioso, este proyecto parametriza factores de riesgo, como la frustración o la desviación brusca de la rutina operativa. Es decir, se buscan comportamientos humanos que delaten al perpetrador. Justificar esta correlación clínico-técnica mediante algoritmos de **aprendizaje automático** (*machine learning*) aporta una solución analítica innovadora al mercado corporativo. Este enfoque permite a los departamentos de seguridad y recursos humanos adelantarse a la ruta crítica del incidente.

1.2. Motivación personal

El presente enfoque surge a partir de una trayectoria profesional de más de dos décadas en la que convergen dos ámbitos tradicionalmente independientes: por un lado, una dilatada experiencia operativa en el sector de la seguridad y las infraestructuras de tecnologías de la información (TI) en entornos institucionales; por otro, la fundamentación académica y práctica en psicología clínica y criminología.

A lo largo del ejercicio profesional, se ha evidenciado cómo la seguridad técnica resulta insuficiente cuando ignora el factor humano. Del mismo modo, la psicología forense carece frecuentemente de herramientas computacionales a gran escala para auditar riesgos en entornos corporativos complejos. Este Trabajo Final de Máster se ha configurado como el marco idóneo para unificar ambas disciplinas. El objetivo a nivel de desarrollo de carrera es consolidar un modelo de auditoría de 'riesgos ciberconductuales' aplicable al sector de la consultoría estratégica de seguridad, aportando un valor diferencial basado en la conjunción de los conocimientos adquiridos en el Máster de Ciencia de Datos y el bagaje clínico previo.

1.3. Objetivos del trabajo

Objetivo Principal:

Desarrollar un **modelo analítico de detección de anomalías** para identificar amenazas internas corporativas, integrando variables técnicas de sistemas de información con indicadores conductuales extraídos mediante el análisis de sentimientos de las comunicaciones organizacionales.

Objetivos Secundarios:

- Preprocesar y estructurar datos heterogéneos y multivariantes del conjunto de datos CERT r4.2 (`logon.csv`, `device.csv`, `http.csv`, `email.csv`) para construir una **matriz de perfiles de actividad por usuario**.
- Aplicar técnicas de Procesamiento de Lenguaje Natural (NLP). Específicamente, emplearemos la extracción de polaridad y subjetividad sobre los metadatos de correos electrónicos para generar **características psicológicas cuantificables**.
- Entrenar y **comparar algoritmos de detección de anomalías no supervisados** (como *Isolation Forest* o *One-Class SVM*) abordando metodológicamente el problema del desbalanceo extremo de clases característico de los incidentes de ciberseguridad.
- **Evaluar el rendimiento del modelo** a través de métricas y el análisis forense de casos de estudio específicos (simulados en la 'Matriz de certeza' de los datos), demostrando su capacidad predictiva en fases tempranas del ciclo de ataque.

1.4. Preguntas de investigación e hipótesis

Para operativizar el objetivo general del proyecto y estructurar el proceso de validación empírica, la presente investigación formula las siguientes preguntas de investigación:

Pregunta de Investigación General (PIG):

¿Es posible anticipar y detectar incidentes de amenaza interna (Insider Threat) en un entorno corporativo mediante la aplicación de modelos de aprendizaje automático no supervisado sobre una matriz conductual que integre volumetría técnica y métricas de deriva psicológica?

Preguntas de Investigación Específicas (PIE):

- **PIE 1 (Psicología y deriva conductual):** ¿En qué medida la cuantificación de la deriva conductual (calculada a través del análisis de sentimiento y el *Z-Score* personalizado de las comunicaciones) mejora la capacidad predictiva de las anomalías frente a un enfoque puramente volumétrico y técnico?
- **PIE 2 (Desbalanceo extremo):** Ante la naturaleza inherentemente escasa del fraude interno, ¿qué grado de eficacia medido en Tasa de Captura (*Recall*) pueden alcanzar algoritmos no supervisados de detección de anomalías sin recurrir a técnicas de sobremuestreo sintético que distorsionen la estructura real del comportamiento organizacional?
- **PIE 3 (Sistema de votación por ensamblaje):** ¿De qué manera la combinación de paradigmas algorítmicos distintos (modelos de partición espacial (*Isolation Forest*) frente a modelos de aprendizaje profundo (*Autoencoders*)) contribuye a maximizar la detección de saboteadores sin incrementar la fatiga de alertas operativa?
- **PIE 4 (Explicabilidad y Aplicabilidad Criminológica):** ¿Es posible traducir las decisiones matemáticas de los modelos predictivos en evidencias operativas y trazables mediante técnicas de Inteligencia Artificial Explicable (XAI), de forma que validen las premisas del modelo criminológico *Critical Path to Insider Risk* (CPIR)?

La hipótesis de trabajo subyacente es que la integración de señales heterogéneas (técnicas y psicológicas) en una matriz conductual unificada producirá un sistema de detección con mayor capacidad de anticipación que cualquiera de los enfoques unidimensionales por separado, manteniendo una tasa de alertas operativamente asumible para los equipos de seguridad.

1.5. Impacto en sostenibilidad, ético-social y de diversidad

El presente Trabajo Final se alinea de manera fundamental con el Objetivo de Desarrollo Sostenible (ODS) 9 (Industria, Innovación e Infraestructura) mediante el desarrollo de tecnologías que fortalecen la ciber-resiliencia corporativa. También con el ODS 16 (Paz, Justicia e

Instituciones Sólidas) al proporcionar mecanismos técnicos para mitigar el fraude interno, el sabotaje y el robo de propiedad intelectual.

Desde la dimensión ética y de diversidad, el modelo de detección propuesto se fundamenta en los principios de **neutralidad algorítmica y privacidad desde el diseño**. Al basar la evaluación del riesgo estrictamente en variables operativas de TI (horarios de conexión, frecuencias de transferencia de datos) y en el procesamiento automatizado del lenguaje natural NLP (el cual opera ciego ante metadatos demográficos), el sistema previene activamente la introducción de sesgos cognitivos o discriminatorios (por género, raza, edad u origen) que frecuentemente contaminan la evaluación humana tradicional en el ámbito corporativo o de recursos humanos. Por tanto, **el impacto social previsto es netamente positivo**, dotando a las organizaciones de un marco de auditoría justo, objetivo y basado exclusivamente en la evidencia conductual-técnica del usuario.

1.6. Enfoque y método seguido

El proyecto se empleará una adaptación del ciclo de vida estándar para proyectos de ciencia de datos (CRISP-DM), integrando como capa inicial un análisis basado en teorías criminológicas (como la ruta crítica del *Insider Threat*). La estrategia metodológica se divide en las siguientes fases:

- **Fase de Comprensión:** Revisión del marco teórico para fundamentar la selección de variables operativas y psicológicas susceptibles de ser vectorizadas.
- **Fase de Preparación de Datos:** Ingesta del conjunto de datos masivo (CERT r4.2) empleando ecosistemas de *Python* (*Pandas/NumPy*). Se ejecutará la limpieza, normalización y agregación en ventanas temporales para unificar registros de actividad técnicos con datos textuales no estructurados.
- **Fase de Ingeniería de Características (*Feature Engineering*):** Extracción de métricas de sentimiento mediante librerías de NLP (NLTK/VADER) y derivación de variables complejas (e.g. desviación estándar de horarios de conexión).
- **Fase de Modelado:** Implementación de algoritmos de detección de valores atípicos (*outliers*) no supervisados, debido a la naturaleza subrepresentada de la clase positiva (atacante) en escenarios reales.
- **Fase de Evaluación:** Validación del modelo contrastando los resultados con la matriz de incidentes inyectada en el conjunto de datos, utilizando curvas Precisión-*Recall* y análisis forense descriptivo de los falsos positivos/negativos.

Se ha considerado esta metodología la óptima pues emula el escenario operativo de un analista de seguridad real, priorizando la fiabilidad y la explicabilidad (clave para entornos empresariales) sobre la aplicación de técnicas de *Deep Learning* de tipo 'caja negra' que dificultan la auditoría conductual.

1.7. Planificación del trabajo

La planificación temporal se ha diseñado mediante un desglose de tareas asociado a las Pruebas de Evaluación Continua (PEC) requeridas por la asignatura:

- **Hito 1 (PEC 1): Definición del Proyecto (Semanas 1-2).** Finalización: 01/03. Establecimiento del alcance, justificación ética/técnica y validación inicial del entorno de trabajo local en *Python* con los datos en bruto.
- **Hito 2 (PEC 2): Estado del Arte (Semanas 3-5).** Finalización: 22/03. Ejecución de la revisión bibliográfica sistemática sobre UEBA y modelos criminológicos en ciberseguridad.
- **Hito 3 (PEC 3): Implementación y Desarrollo (Semanas 6-12).** Finalización: 10/05. Programación del *pipeline* de datos, aplicación de técnicas de NLP, entrenamiento de los modelos de detección de anomalías y extracción tabular/visual de resultados.
- **Hito 4 (PEC 4): Redacción y Presentación (Semanas 13-15).** Finalización: 02/06. Integración progresiva de los capítulos metodológicos, consolidación de la memoria final y grabación de la presentación audiovisual en formato continuo.
- **Hito 5 (PEC 5): Defensa Pública (Semanas 16-19).** Finalización: 26/06. Revisión de posibles cuestiones planteadas por el tribunal y defensa síncrona/asíncrona del Trabajo Final.

1.7.1. Gestión de Riesgos:

El principal riesgo detectado es la saturación de recursos computacionales locales (RAM) debido a la volumetría de los datos (múltiples *gigabytes* en memoria). El plan de mitigación consiste en aplicar técnicas de lectura por lotes (*chunking*) mediante **pandas** o, en caso de persistir el bloqueo, la reducción de la muestra poblacional a un subconjunto aleatorio representativo para la validación del modelo (e.g. 200 usuarios).

1.8. Declaración sobre el uso de inteligencia artificial generativa

El presente trabajo ha hecho uso de herramientas de inteligencia artificial generativa de forma diferenciada según la fase del proyecto:

- **Hasta la entrega de la PEC2/M2 (10 de marzo de 2026):** No se emplearon herramientas de inteligencia artificial generativa en ninguna fase de investigación, redacción o análisis. El documento entregado y evaluado fue elaborado íntegramente por el autor.

- **Durante la PEC3/M3 (desde el 11 de marzo de 2026):** Se ha empleado el modelo de lenguaje **Claude** (Anthropic, 2025) como herramienta de asesoramiento y revisión en las siguientes tareas específicas: (a) verificación de coherencia entre los resultados de los cuadernos de programación y el texto de la memoria; (b) orientación sobre la estructura y ubicación de secciones en el documento; y (c) revisión crítica del redactado académico de secciones elaboradas por el autor. El diseño metodológico, la implementación del código, el análisis de resultados y la interpretación criminológica y psicológica del trabajo son íntegramente atribuibles al autor. Los textos han sido revisados y validados críticamente antes de su incorporación al documento.

Esta declaración se realiza en cumplimiento de la política académica de integridad de la Universitat Oberta de Catalunya (UOC) sobre el uso ético y transparente de herramientas de inteligencia artificial generativa en trabajos finales de máster.

Capítulo 2

Estado del arte

La detección de la amenaza interna (*insider threat*) representa uno de los desafíos más asimétricos en el ámbito de la ciberseguridad. A diferencia de los actores externos, en este escenario el atacante interno ya posee acceso legítimo a los sistemas de la organización. Asimismo, se asume un conocimiento implícito de la arquitectura de defensa y, consecuentemente, el usuario disfruta de niveles de confianza o permisos otorgados por la propia entidad. Por otro lado, la política de adjudicación y control de dichos privilegios suele adolecer de una planificación deliberada o de revisiones periódicas estructuradas.

Adicionalmente, es habitual que no se haya analizado de forma sistemática el perfil conductual del empleado. Las organizaciones no suelen contemplar la posibilidad de que se produzcan variaciones en la relación laboral a lo largo de un proceso diacrónico, especialmente ante los sucesos del ciclo vital y profesional del trabajador. Para contextualizar el enfoque híbrido propuesto en este trabajo, en el presente capítulo se examina la literatura académica y el estado actual de la industria desde tres ejes convergentes: los modelos teóricos de la criminología corporativa, las soluciones técnicas de análisis de comportamiento de usuarios y entidades (*User and Entity Behavior Analytics*, UEBA) y la aplicación del procesamiento de lenguaje natural (*Natural Language Processing*, NLP) para la inferencia de estados psicológicos de riesgo.

2.1. Criminología corporativa y la psicología del atacante interno

La literatura criminológica ha analizado de manera reiterada la motivación subyacente al fraude y el sabotaje corporativo. El clásico Triángulo del Fraude (Cressey, 1973) establece que el acto delictivo requiere la convergencia de tres factores: la oportunidad (el acceso técnico), la motivación (presiones financieras o agravios) y la racionalización (la justificación cognitiva del acto). Asimismo, en el ámbito de la inteligencia, el acrónimo MICE (*Money, Ideology, Coercion, Ego*) ha servido tradicionalmente para categorizar las motivaciones del espionaje.

Sin embargo, la aproximación más operativa para este Trabajo Final es el modelo de la ruta crítica del riesgo interno o *Critical Path to Insider Risk* (CPIR), desarrollado por Shaw y

Sellers (2015). Este modelo postula que la amenaza interna no es un evento espontáneo, sino el resultado de un proceso progresivo que se inicia con estresores personales o profesionales, evoluciona hacia comportamientos preocupantes (*concerning behaviors*) y culmina en la acción maliciosa. Diferentes estudios constatan que este periodo de incubación (conocido como deriva conductual o *behavioral drift*) presenta una duración promedio de 73 días antes de la ejecución del ataque.

Desde una perspectiva psicológica, Greitzer y Frincke (2010) subrayan la conveniencia de incorporar datos psicosociales a las auditorías técnicas, argumentando que el análisis exclusivo de eventos informáticos resulta ajeno a la intención del usuario. En consecuencia, la tecnología por sí sola, carente de contexto humano, puede resultar insuficiente para anticipar la motivación ; de ahí la relevancia de perfilar la conducta para evaluar el riesgo antes de que se materialice en un incidente técnico de gravedad.

2.2. Análisis de Comportamiento de Usuarios y Entidades (UEBA)

Históricamente, la detección de intrusiones se ha fundamentado en sistemas de gestión de información y eventos de seguridad (*Security Information and Event Management*, SIEM), los cuales operan mediante reglas estáticas y heurísticas predefinidas. Sin embargo, como apuntan numerosos autores, estas soluciones perimetrales pueden mostrarse insuficientes frente al atacante interno, en tanto que sus credenciales son legítimas y sus acciones técnicas son susceptibles de mimetizarse con el flujo de trabajo diario de un empleado o con su propia descripción de puesto (Al-Mhiquani et al., 2020; Yuan & Wu, 2021).

Ante esta limitación, la industria ha pivotado hacia el Análisis de Comportamiento de Usuarios y Entidades (*User and Entity Behavior Analytics*, UEBA). Este paradigma abandona la búsqueda de la 'firma del *malware*' en favor de la creación de una línea base (*baseline*) que parametriza el comportamiento normal o habitual de un individuo (Mladenovic et al., 2024).

Para lograr este perfilado dinámico, la investigación contemporánea suele apoyarse en el aprendizaje automático (*machine learning*) y, en concreto, en los enfoques no supervisados. La justificación empírica de esta elección radica en la extrema rareza estadística de los incidentes internos: en un entorno corporativo masivo, la clase positiva (el atacante) representa una fracción minúscula de los datos, lo que dificulta el entrenamiento de modelos supervisados tradicionales (Tuor et al., 2017).

En este contexto, algoritmos de detección de anomalías como *Isolation Forest*, redes neuronales autocodificadoras (*autoencoders*) o *One-Class SVM*, han demostrado eficacia al identificar desviaciones sutiles en los patrones de conexión o transferencia de archivos. No obstante, la literatura también advierte de un escollo inherente al enfoque puramente técnico: la dependencia exclusiva de los registros de actividad de red genera altas tasas de falsos positivos (Haq y Alshehri, 2022). Un empleado trabajando de madrugada o descargando una cantidad inusual de datos por exigencias de un proyecto urgente puede ser etiquetado como 'anómalo' por el

modelo, pudiendo saturar al equipo de seguridad con alertas que carecen de contexto clínico o intencional (Wei et al., 2024).

2.3. Procesamiento de Lenguaje Natural (NLP) en ciberseguridad

La brecha explicativa que presentan los sistemas UEBA estrictamente operacionales ha impulsado la integración del procesamiento de lenguaje natural (*Natural Language Processing*, NLP) como un puente hacia la evaluación de los estados psicológicos del sujeto (Soh et al., 2019). Retomando el modelo CPIR, si el origen de la amenaza se encuentra en un estresor que desencadena un cambio de actitud, las comunicaciones corporativas internas (tales como el correo electrónico) se configuran como un canal idóneo para evaluar dicha fricción afectiva.

Múltiples estudios sugieren que el análisis de sentimiento (*sentiment analysis*) aplicado a los correos electrónicos mediante diccionarios léxicos (como el algoritmo VADER) o técnicas de incrustación de palabras (*word embedding*), permite extraer indicadores conductuales cuantificables antes de que se produzca la exfiltración técnica (Haq y Alshehri, 2022).

La extracción de métricas como la polaridad (positiva, negativa o neutra) y la subjetividad en las comunicaciones ha sido evaluada de forma recurrente mediante conjuntos de datos sintéticos, siendo el entorno CERT (versiones r4.2 o r6.2) un estándar académico de referencia habitual (Asad, s.f.; Glasser y Lindauer, 2013). En estos escenarios controlados, se observa cómo los usuarios sometidos a presiones disciplinarias o desafección laboral tienden a reflejar un ensombrecimiento (*darkening*) en su lenguaje meses antes de cometer actos de sabotaje informático (Le et al., 2020).

2.4. Justificación y aportación diferencial de la propuesta

A pesar de los avances significativos en la ciberseguridad corporativa, la amenaza interna (*insider threat*) continúa siendo uno de los desafíos más complejos y costosos para las organizaciones, representando una parte sustancial de los incidentes de seguridad críticos (Al-Mhiqani et al., 2020). La revisión de la literatura científica evidencia una brecha metodológica y conceptual en la forma en que la industria y la academia abordan este problema: **la desconexión entre la psicología teórica y la monitorización técnica de sistemas** (Ohu & Jones, 2025).

Por un lado, las herramientas técnicas tradicionales y los sistemas avanzados de análisis de comportamiento de usuarios y entidades (UEBA) procesan grandes volúmenes de registros de actividad de red (*logs*), pero carecen de visibilidad respecto al contexto humano y emocional del usuario (Fayyad, 2025). Al omitir esta dimensión psicosocial, dichos sistemas suelen generar un volumen elevado de falsos positivos y la consecuente fatiga de alertas, catalogando como amenazas ciertos comportamientos que, aun siendo estadísticamente atípicos, resultan benignos (Khan & Arshad, 2022).

Por otro lado, la psicología conductual y la criminología corporativa proporcionan marcos teóricos de gran utilidad para comprender la motivación del atacante (como el modelo MICE, el Triángulo del Fraude de Cressey o la ruta crítica del modelo CPIR), pero estos suelen aplicarse *a posteriori* en investigaciones forenses, presentando limitaciones de escalabilidad computacional para la prevención en tiempo real (Ohu & Jones, 2025).

La aportación diferencial de este Trabajo Final de Máster consiste en articular un nexo entre ambas disciplinas. La propuesta se centra en unificar la detección de anomalías estadísticas de red con el procesamiento de lenguaje natural (NLP) aplicado a las comunicaciones corporativas mediante el análisis de sentimiento, con el fin de mitigar las limitaciones de los enfoques unidimensionales.

Este enfoque híbrido aporta tres contribuciones específicas:

1. **Detección temprana orientada a la fase de ideación (ruta crítica).**

A diferencia de los sistemas reactivos, que operan cuando la exfiltración de datos o el sabotaje ya se han iniciado, este modelo plantea el uso del procesamiento de lenguaje natural como un indicador proactivo. La literatura señala que los actores internos suelen atravesar una fase de deriva conductual (*behavioral drift*) y disonancia cognitiva observable con anterioridad a la comisión del incidente (Soh et al., 2019; Fayyad, 2025). Al monitorizar la evolución temporal del estado afectivo (como el incremento de expresiones de hostilidad o el descenso de la polaridad positiva en los correos electrónicos), el prototipo facilita la evaluación del riesgo en las etapas tempranas de predisposición e ideación descritas en el modelo CPIR.

2. **Atenuación de falsos positivos.**

La integración del estado emocional del empleado permite contextualizar la anomalía técnica. Una desviación en la actividad nocturna o un volumen atípico de descargas deja de evaluarse como una mera alteración estadística; al cruzarse con indicadores lingüísticos asociados al estrés, la frustración o la desafección laboral, el sistema complementa la alerta técnica con evidencia psicosocial. En la literatura contemporánea, este análisis multimodal se constata como una vía eficaz para reducir los falsos positivos que penalizan la operatividad de los sistemas de seguridad convencionales (Fayyad, 2025; Singh et al., 2022).

3. **Capa forense explicable con fundamentación criminológica.**

El empleo de algoritmos de aprendizaje automático (*machine learning*) y aprendizaje profundo (*deep learning*) suele presentar la limitación operativa del efecto de 'caja negra', donde el sistema calcula un nivel de riesgo sin detallar las variables subyacentes (Nanamou et al., 2024; Fayyad, 2025). La propuesta metodológica de este trabajo aborda dicha limitación traduciendo las métricas matemáticas en una narrativa interpretable desde la perspectiva criminológica. Más allá de clasificar un registro como atípico en un espacio vectorial, se incorpora una capa explicativa que aporta contexto intencional a la alerta, facilitando el análisis forense para determinar si el indicador de riesgo guarda relación con factores de codicia, venganza o coacción descritos en el modelo MICE.

En consecuencia, este proyecto no busca únicamente optimizar un clasificador binario, sino transformar un problema de naturaleza estrictamente técnica en un modelo de inteligencia conductual aplicada. Al dotar a los registros de actividad de red de un contexto clínico e intencional, el prototipo proporciona a los departamentos de seguridad y recursos humanos una herramienta auditable y ética, orientada a facilitar la intervención temprana y el apoyo al empleado antes de la materialización de un incidente crítico.

Capítulo 3

Materiales y métodos

3.1. Diseño y desarrollo del trabajo

El diseño de la presente investigación se ha estructurado en torno a la validación empírica del modelo criminológico de la ruta crítica del riesgo interno o *Critical Path to Insider Risk* (CPIR). Para ello, se planteó el desarrollo de un sistema de detección analítico capaz de integrar la volumetría técnica de los usuarios (interacciones con los sistemas, transferencias de archivos, gestión de horarios, entre otros) con un perfilado psicológico dinámico centrado en la deriva conductual y afectiva.

El estudio se ha ejecutado utilizando el conjunto de datos CERT r4.2, el cual constituye una simulación sintética de alta fidelidad que proporciona un entorno controlado compuesto por miles de usuarios legítimos y una densidad conocida de actores internos (*insiders*). El proceso de desarrollo se dividió en cuatro fases operativas claramente delimitadas:

1. **Análisis exploratorio:** examen detallado del conjunto de fuentes que componen el entorno CERT r4.2 con el fin de establecer los patrones de referencia, evaluar la calidad de la información y fundamentar las decisiones metodológicas iniciales.
2. **Ingesta y agregación de fuentes heterogéneas:** procesamiento y unificación de los registros de actividad web (*http*), inicios de sesión (*logon*), uso de dispositivos externos (*usb*), flujos de archivos (*file*), correo electrónico (*email*), métricas psicométricas (*psychometric*) y el directorio LDAP, este último acotado al periodo de actividad más reciente.
3. **Ingeniería de características:** extracción, selección y transformación de variables, aplicando técnicas de procesamiento de lenguaje natural (NLP) orientadas a evaluar el estado afectivo y el sentimiento en las comunicaciones escritas.
4. **Modelado algorítmico y análisis forense:** con el objeto de mitigar el riesgo de sobreajuste (*overfitting*), se implementaron dos salvaguardas complementarias durante el diseño de la arquitectura. En primer lugar, se incorporaron capas de regularización por omisión (*dropout*) con una tasa de 0.2 en el bloque codificador (*encoder*), orientadas a que la red neuronal aprenda representaciones generalizables y distribuidas en lugar de

memorizar el ruido inherente al conjunto de entrenamiento. En segundo lugar, se estableció una partición de validación durante la fase de entrenamiento (`validation_split = 0.1`), lo que permitió monitorizar la curva de pérdida sobre datos no vistos y evaluar posibles desviaciones entre el error de entrenamiento y el de validación. Las curvas de convergencia evidenciaron una reducción progresiva de ambas métricas a lo largo de las 10 épocas, sugiriendo la ausencia de un sobreajuste significativo en el modelo.

3.2. Metodología y toma de decisiones

Dada la naturaleza criminológica del problema, donde la amenaza interna constituye un evento altamente anómalo y escaso frente a la masiva actividad corporativa legítima, se descartó el uso de algoritmos de clasificación supervisada.

- **Alternativas consideradas y descartadas:** Se evaluó la posibilidad de emplear técnicas de sobremuestreo tales como muestreo aleatorio, *SMOTE*, *SMOTE-NC* o *ADASYN*. El fin era equilibrar las clases y permitir la aplicación de modelos supervisados convencionales como el algoritmo de bosques aleatorios (*Random Forest*). Sin embargo, se rechazó metodológicamente esta opción debido a que la generación artificial de eventos maliciosos sintéticos distorsionaría la realidad clínica y técnica del entorno operacional, invalidando la premisa fundamental de aislar variaciones psicológicas sutiles.
- **Decisión adoptada:** Se optó por un paradigma de aprendizaje automático no supervisado (*unsupervised learning*) especializado en la detección de anomalías. En este marco, se seleccionó el algoritmo de bosque de aislamiento (*Isolation Forest*) como modelo de referencia (*baseline*), debido a su eficiencia computacional en el aislamiento de valores atípicos (*outliers*) mediante particiones espaciales ortogonales. De forma complementaria, se incorporaron arquitecturas de aprendizaje profundo mediante autocodificadores (*autoencoders*), orientadas a capturar las relaciones no lineales complejas existentes entre las métricas psicométricas y la telemetría de actividad técnica.

3.2.1. Selección y justificación de hiperparámetros

Dado el paradigma de aprendizaje no supervisado adoptado, la optimización de hiperparámetros no pudo realizarse mediante los métodos convencionales de validación cruzada supervisada, tales como la búsqueda en rejilla (*Grid Search*) o la búsqueda aleatoria (*Random Search*) basadas en métricas clásicas de clasificación. Estos enfoques requieren la presencia de etiquetas de clase durante el proceso de ajuste, lo que introduciría un fenómeno de fuga de datos (*data leakage*) al explotar de forma prematura la matriz de certeza (*ground truth*).

En su lugar, la selección de los hiperparámetros se fundamentó en un **razonamiento operativo explícito**:

- ***Isolation Forest*:** Se estableció el parámetro de contaminación en `contamination = 0.005` (0.5 %) como un reflejo directo de las restricciones operativas reales de un centro de operaciones de seguridad (SOC) o un departamento de Recursos Humanos. Este

umbral garantiza un volumen de alertas gestionable, evitando la fatiga operativa de los analistas. Asimismo, el número de estimadores se fijó en `n_estimators = 200`, un valor superior al estándar mínimo recomendado en la literatura científica (100) para asegurar la estabilidad en la asignación de puntuaciones de riesgo en espacios de alta dimensionalidad. Ambas configuraciones constituyen decisiones de diseño con justificación criminológica y de usabilidad, desmarcándose de una optimización ciega ajena al contexto del entorno corporativo.

- **Autocodificador (*Autoencoder*):** La arquitectura de tipo embudo (16-8-4-8-16) se seleccionó siguiendo los criterios consolidados en la literatura para conjuntos de dimensionalidad moderada (11 variables de entrada), asegurando una compresión idónea en el espacio latente sin subespecificar la capacidad de representación de la red. El número de épocas de entrenamiento (10) se determinó mediante la inspección visual de las curvas de pérdida de los conjuntos de entrenamiento y validación, las cuales evidenciaron una convergencia estable sin divergencias, lo que descarta la presencia de un sobreajuste significativo.

Esta estrategia de justificación operativa de hiperparámetros constituye la práctica habitual en el despliegue de sistemas de análisis de comportamiento (UEBA) en entornos reales, donde el umbral de activación responde a criterios de gestión de riesgos organizacionales y no a un mero óptimo estadístico abstracto (Wei et al., 2024).

Asimismo, con el objeto de prevenir la fuga de datos (*data leakage*) en el cálculo de la deriva psicológica, se implementaron ventanas móviles históricas desplazadas (`shift(1)`). Esta medida garantiza que el estado emocional del usuario se evalúe exclusivamente en contraste con su propio histórico inmediato, simulando fielmente las condiciones de un entorno de producción real.

Finalmente, se procedió a la formalización explícita de las preguntas de investigación de este proyecto. Esta delimitación metodológica se estructuró de manera definitiva una vez que la fase de modelado empírico permitió acotar con precisión matemática los interrogantes específicos que el sistema es capaz de resolver, asegurando una coherencia interna estricta entre las hipótesis planteadas y la capacidad analítica del prototipo desarrollado.

3.3. Limitaciones del conjunto de datos y validez ecológica

La naturaleza sintética del conjunto de datos CERT r4.2 introduce una limitación estructural que conviene abordar con rigor antes de interpretar los resultados: el mapeo de variables técnicas a parámetros psicológicos compromete la **validez ecológica** del entorno de simulación.

En psicología y metodología de la investigación, la validez ecológica define el **grado en que los resultados obtenidos en un entorno controlado son representativos y generalizables a los comportamientos y situaciones de la vida real** (Sollod et al., 2009; Bronfenbrenner,

1977). No se trata de un atributo binario sino de un continuo: cuanto más artificiales son las condiciones de producción de los datos, menor es la confianza en que las relaciones estadísticas detectadas reflejen dinámicas genuinas del comportamiento humano fuera del entorno simulado.

El entorno CERT r4.2 fue desarrollado por ingenieros de la Universidad *Carnegie Mellon* como un problema de optimización matemática. Los valores asignados a cada dimensión del modelo de los cinco grandes (*Big Five*) no provienen de evaluaciones psicométricas reales, sino de *proxies* técnicos: la impuntualidad de forma reiterada en el registro de entrada se traduce en un valor bajo en Responsabilidad (C); el volumen y la red de destinatarios de los correos electrónicos del archivo LDAP se emplean para estimar la Extraversión (E), replicando este criterio interpretativo para el resto de las dimensiones con base en reglas técnicas predefinidas.

Este sistema de mapeado resulta, en términos clínicos, **ajeno al contexto**: no permite distinguir entre un empleado descontento y uno que cuida a un familiar enfermo, o entre una baja productividad motivada por un proceso de duelo y una derivada de una desafección laboral activa. El modelo únicamente observa una desviación en la hora de fichaje o un cambio en la volumetría de correos e infiere, a partir de dicha alteración, un rasgo estático de personalidad, omitiendo las transiciones vitales o los procesos biológicos normativos del individuo.

Asumir que una métrica técnica refleja un constructo psicológico estable no solo resulta metodológicamente aventurado, sino que en el marco normativo europeo —especialmente bajo el RGPD y la Ley de Inteligencia Artificial (*AI Act*)— (Reglamento (UE) 2016/679 de 27 de abril de 2016; Reglamento (UE) 2024/1689 de 13 de junio de 2024) constituiría una base insuficiente para fundamentar decisiones con efectos jurídicos sobre el individuo. Este proyecto es consciente de dicha limitación; por este motivo, el análisis SHAP evidenció que el modelo final **no discrimina en función de los rasgos de personalidad** (cuya contribución resultó marginal), sino sobre comportamientos técnicos dinámicos y observables. Esta disociación entre el dato psicométrico sintético y la señal real de anomalía constituye, paradójicamente, una salvaguarda de la coherencia y la viabilidad ética del sistema.

Las razones por las que cualquier conjunto de datos sintético que emplee variables representativas del comportamiento humano presenta limitaciones de validez ecológica pueden sintetizarse en tres ejes:

- **Ausencia de contexto dinámico.** Ningún modelo de personalidad, incluido el *Big Five*, opera en el vacío. La validez ecológica exige observar cómo rasgos como el neuroticismo o la extraversión se manifiestan ante estímulos ambientales específicos: estrés laboral, conflictos interpersonales o cambios organizacionales. Un dato estático asignado por regla técnica omite esta covarianza situacional por diseño.
- **Artificialidad de la distribución.** Si los valores psicométricos fueron generados mediante distribuciones estadísticas predefinidas (e.g., gaussianas) sin considerar la covarianza real entre rasgos y conductas observables, el conjunto de datos posee únicamente **validez interna** (coherencia matemática) pero carece de **validez externa o ecológica**. La regularidad estadística no equivale a representatividad conductual.

- **Ausencia de representatividad funcional.** En el ámbito de la salud mental, la validez ecológica depende de la capacidad predictiva del constructo sobre conductas reales en entornos cotidianos. Un perfil sintético puede presentar un valor extremo en Apertura a la experiencia (O), pero si ese valor no guarda relación con ninguna conducta observable en el entorno laboral real, la variable opera como un constructo vacío sin poder explicativo genuino.

Estas limitaciones no invalidan los resultados obtenidos en este proyecto, los cuales deben interpretarse como una **prueba de concepto metodológica** sobre datos de referencia académica. Sin embargo, sí señalan la dirección prioritaria del trabajo futuro: la validación del flujo de procesamiento (*pipeline*) sobre datos reales (anonimizados y tratados conforme al marco normativo vigente) se configura como el paso necesario para que el sistema transite del laboratorio al entorno operativo.

3.4. Productos obtenidos

Como resultado de esta fase metodológica, se generaron los siguientes artefactos clave:

1. **Matriz maestra de eventos (*master matrix*):**
Base de datos estructurada fundacional que consolida y alinea cronológicamente las fuentes heterogéneas en bruto (registros de directorio LDAP, inicios de sesión, navegación web, uso de dispositivos USB, flujos de archivos y correo electrónico), vinculando la actividad técnica diaria con los rasgos estáticos de personalidad del modelo de los cinco grandes (*Big Five*) de cada empleado.
2. **Matriz de características conductuales (*feature matrix*):**
Conjunto de datos analítico definitivo (compuesto por más de 330.000 registros y 33 dimensiones) que presenta el resultado de aplicar ingeniería de características (*feature engineering*) sobre la matriz maestra. Habilita la extracción de variables complejas de alto valor predictivo, tales como ratios de nocturnidad, conteos volumétricos y ventanas estadísticas desplazadas para prevenir la fuga de datos (*data leakage*).
3. **Modelo de procesamiento de lenguaje natural para la deriva afectiva:**
Flujo de procesamiento (*pipeline*) de procesamiento de lenguaje natural y análisis de sentimiento diseñado para cuantificar matemáticamente el tono de las comunicaciones escritas, generando la puntuación estándar (*Z-score*) de desviación afectiva que actúa como indicador temprano de estresores contextuales.
4. **Sistema de detección híbrido (*ensemble*):**
Motor de inferencia operativo que combina las predicciones ortogonales de un modelo de bosque de aislamiento (*Isolation Forest*) con el análisis de relaciones no lineales de una arquitectura de aprendizaje profundo mediante autocodificadores (*autoencoders*). Este sistema prioriza el riesgo crítico con base en la modelización criminológica, permitiendo alcanzar tasas de captura estadísticamente significativas sin saturar al equipo de seguridad con alertas de riesgo redundantes.

5. **Prueba de concepto interactiva (*web application*):**

Despliegue de una interfaz gráfica de usuario (*front-end*) que encapsula el sistema de ensamblado (*ensemble*) y el motor de explicabilidad SHAP, facilitando la auditoría forense de perfiles conductuales en tiempo real.

6. **Conjunto de datos curado y matriz de características publicados en abierto (*Zenodo*):**

El conjunto de datos curado y la matriz de características analítica han sido publicados en acceso abierto bajo licencia CC-BY-NC 4.0 en el repositorio científico federado (Barrera Mora, 2026).

7. **Repositorio oficial del TFM (*GitHub*):**

Repositorio de código que aloja la totalidad de los contenidos, artefactos de programación y documentos de soporte del proyecto (https://github.com/AnbarTop/Human_centered_internal_threat_detection.git).

Capítulo 4

Resultados

La aplicación del marco metodológico sobre el conjunto de datos CERT r4.2 aporta indicios favorables sobre la viabilidad de anticipar la amenaza interna utilizando la deriva conductual como indicador temprano. El conjunto de datos contiene **191 perfiles de actores internos (*insiders*) confirmados** distribuidos entre 330.452 registros de actividad diaria por usuario, lo que implica una proporción de desbalanceo de clases de aproximadamente 1:1.730. Dado este contexto, y con el objeto de emular la restricción operativa real de un departamento de Seguridad o Recursos Humanos (minimizando la fatiga de alertas), se acotó el análisis al **0.5 % superior de los eventos** clasificados con mayor índice de riesgo, lo que equivale a investigar únicamente 1.653 días-usuario sobre el total de la actividad corporativa registrada.

1. Línea base de comparación (*Isolation Forest*):

El modelo primario logró aislar la actividad sospechosa alcanzando un Área Bajo la Curva (AUC) de 0.629, situándose estadísticamente por encima del nivel de azar (0.5). En términos operativos, al contrastar las alertas del umbral crítico (0.5 %) con la matriz de certeza (*ground truth*), el modelo interceptó a **9 atacantes confirmados**, lo que representa una tasa de captura (*recall*) del **4.71 %** sobre el total de las 191 amenazas reales indexadas.

Aunque este porcentaje pueda parecer reducido bajo los estándares de la clasificación supervisada tradicional, en el marco del aprendizaje no supervisado (donde el algoritmo opera sin etiquetas previas sobre la naturaleza del ataque), el resultado sugiere que las variables de deriva psicológica combinadas con la volumetría técnica aportan una **capacidad predictiva intrínseca**. El modelo aisló de forma autónoma a saboteadores documentados, como el usuario MPM0220, aportando evidencia de que el proceso descrito en el modelo CPIR genera una huella estadística detectable en los registros de actividad antes de la fase de exfiltración.

2. Modelado mediante redes neuronales (*Autoencoder*):

La aplicación de la arquitectura de aprendizaje profundo mejoró de forma notoria la capacidad de detección en el umbral crítico seleccionado. Manteniendo la restricción operativa

del 0.5 %, el autocodificador (*autoencoder*) interceptó a **22 atacantes confirmados**. Esto representa una tasa de captura del **11.52 %**, lo que supone un incremento relativo del 145 % respecto al modelo base, si bien el AUC global descendió a 0.551, situándose próximo al nivel de azar.

Este fenómeno, aparentemente paradójico, constituye un comportamiento esperado en problemas analíticos con desbalanceo extremo de clases: la red neuronal aprende a reconstruir con alta fidelidad las pautas del comportamiento corporativo rutinario, concentrando el máximo error de reconstrucción (*anomaly score* o puntuación de anomalía) en los perfiles maliciosos. No obstante, al no discriminar con la misma especificidad los matices de variación interna dentro de la inmensa masa de actividad legítima, métricas globales como el AUC tienden a resentirse. Esta observación corrobora que, en el ámbito de la ciberseguridad, la métrica operativamente relevante se halla en el rendimiento de captura en los umbrales superiores (*Recall@Top-K*), y no en los indicadores de distribución global.

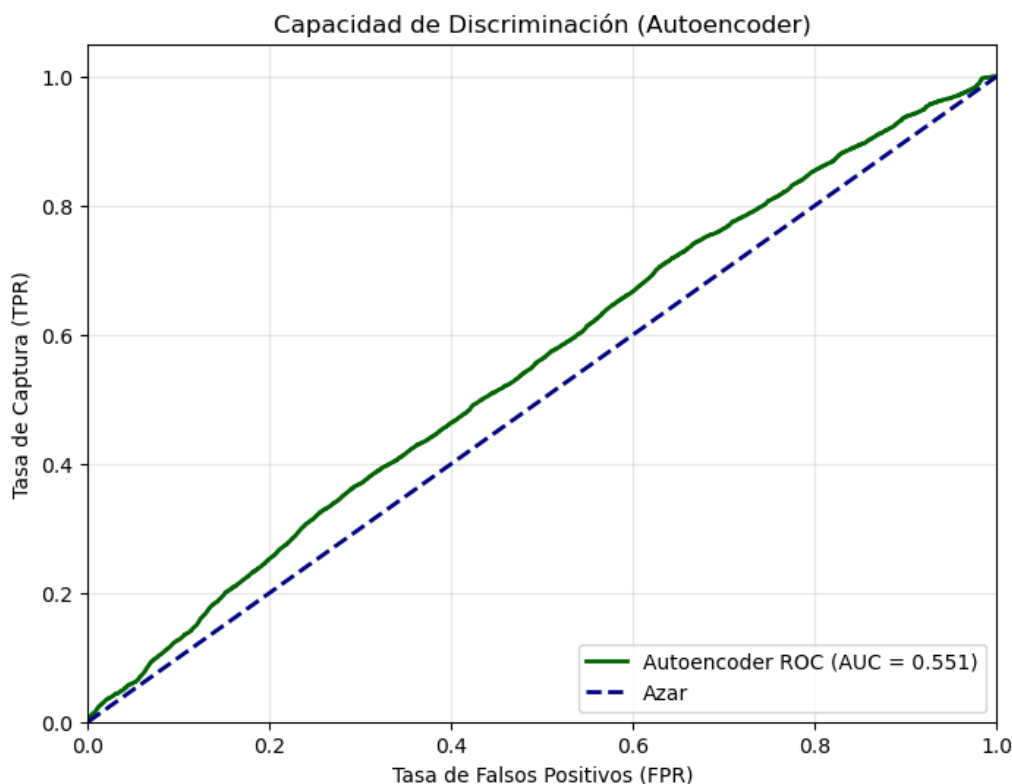


Figura 4.1: Curva ROC del Autoencoder (AUC = 0.551). La variación respecto al AUC del *Isolation Forest* (0.629) ilustra el efecto que supone para la métrica global la concentración del error de reconstrucción en el umbral crítico superior.

3. Sistema de votación por ensamblado (*Ensemble*):

Análisis cruzados de las detecciones evidenciaron una complementariedad táctica entre ambos modelos: 6 atacantes fueron identificados simultáneamente por ambos algoritmos

(lo que denota una señal de riesgo crítico de alta fiabilidad), el autocodificador afloró a 16 saboteadores que eludieron las particiones ortogonales del *Isolation Forest*, mientras que el modelo base interceptó a 3 usuarios atípicos que la red neuronal había reconstruido con éxito. La implementación de un sistema de ensamblado (*ensemble*) fundamentado en la unión lógica de alertas elevó el resultado a **24 atacantes detectados** dentro de la cuota fija del 0.5 % de eventos investigados, alcanzando una tasa de captura (*recall*) final del **12.57 %** sin incrementar el coste ni el volumen de las investigaciones forenses.

4. Explicabilidad del modelo (*SHapley Additive exPlanations*):

Adicionalmente, la integración de la capa de explicabilidad mediante el uso de valores SHAP permitió auditar las decisiones del algoritmo de forma transparente. El análisis forense del caso confirmado MPM0220 reflejó que la alerta crítica fue activada por la convergencia de cuatro señales técnico-conductuales de alta magnitud, cuyos valores específicos se detallan en la Tabla 4.1.

Variable	Valor SHAP	Interpretación criminológica
after_hours_activity	-1,99	Explotación de ventanas de baja supervisión (CPIR: fase activa)
total_logon_activity	-1,86	Hiperactividad técnica / movimientos laterales en la red
usb_activity_count	-1,78	Canal de exfiltración activo (modelo del triángulo del fraude)
file_activity_count	-1,73	Acceso masivo a sistemas de archivos corporativos
sentiment_z_user	-0,42	Deriva afectiva (Z -score = -2,817): confirmador motivacional
Rasgos del <i>Big Five</i> (O, C, E, A, N)	≈ 0	Sin contribución discriminante significativa

Cuadro 4.1: Descomposición SHAP del evento crítico del usuario confirmado MPM0220 (2010-10-04). El valor base del modelo de referencia se sitúa en $E[f(X)] = 12,306$, resultando una predicción final de $f(x) = 4,369$.

Los datos analizados aportan conclusiones en dos vertientes relevantes. Por un lado, sugieren que **la deriva conductual y la actividad técnica operan como los predictores estructurales del riesgo**, mientras que el estado afectivo actúa como un **confirmador de la intencionalidad** encargado de contextualizar la anomalía puramente estadística. Una actividad fuera de horario con uso de dispositivos USB puede deberse a contingencias operativas ordinarias; sin embargo, esa misma acción técnica en un empleado cuyas comunicaciones muestran un descenso afectivo de casi tres desviaciones estándar por debajo de su propia línea base histórica incrementa significativamente la probabilidad de un escenario de riesgo. Por otro lado, la contribución marginal de los rasgos estáticos de personalidad (*Big Five*) en el umbral crítico **asegura que el sistema no discrimina por perfiles psicométricos innatos**, lo que se configura como la principal salvaguarda ética y legal del modelo para su uso potencial en entornos organizacionales.

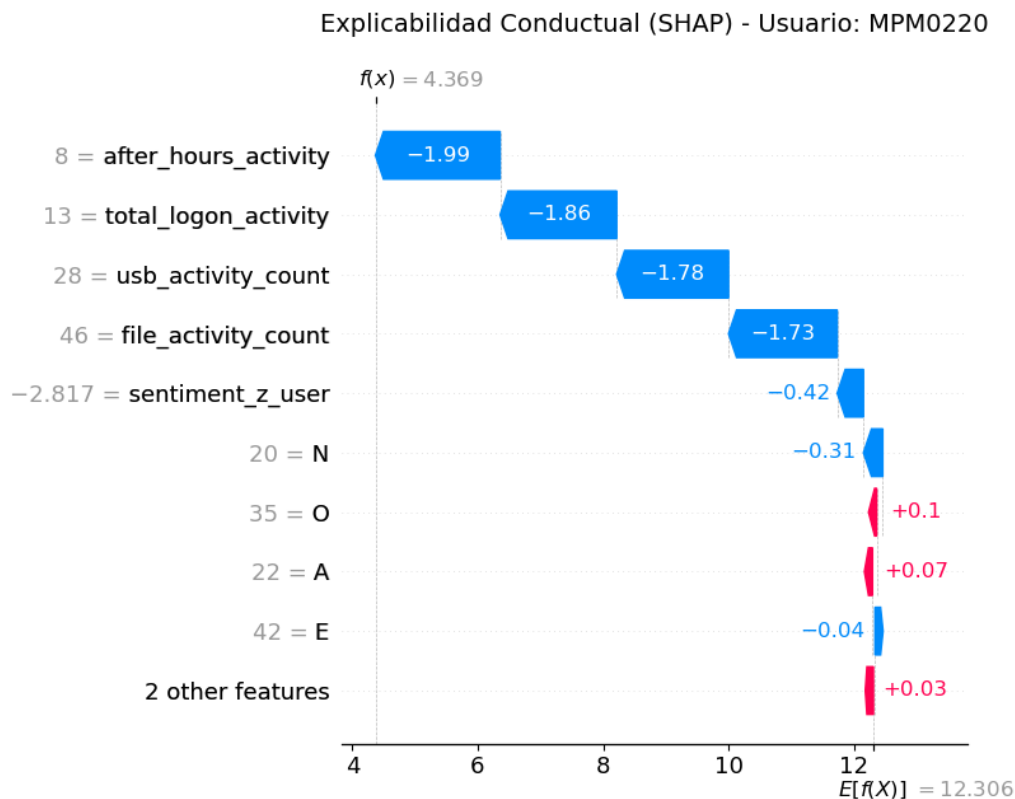


Figura 4.2: Gráfico de cascada SHAP del usuario MPM0220. Las barras en tonalidad roja indican variables que empujan la puntuación de anomalía hacia un mayor índice de riesgo, mientras que las azules la orientan hacia la normalidad operativa. La variable de mayor contribución corresponde a la actividad fuera de horario, seguida de la hiperactividad en inicios de sesión y el uso de dispositivos USB.

5. Despliegue operativo y prueba de concepto (*Hugging Face Spaces*):

Con el propósito de evidenciar la viabilidad operativa del sistema diseñado y facilitar su evaluación directa en el marco de un Centro de Operaciones de Seguridad (SOC), los modelos entrenados (*Isolation Forest* y *Autoencoder*) junto con el módulo explicativo SHAP han sido empaquetados y desplegados en una aplicación web interactiva.

Esta prueba de concepto faculta a un evaluador para modificar las variables conductuales de forma dinámica y observar cómo el sistema integrado recalcula el índice de riesgo global, reasignando los pesos analíticos en tiempo real. La herramienta se encuentra disponible para su revisión pública a través del siguiente enlace institucional:

<https://huggingface.co/spaces/Kamaranis/Internal-Threat-Detection-Ensemble-CPIR>

Capítulo 5

Discusión

Los resultados obtenidos permiten estructurar la respuesta a las preguntas de investigación formuladas en la introducción, contrastándolas con la evidencia empírica extraída a partir del conjunto de datos CERT r4.2.

5.1. El sentimiento como confirmador, no como activador (PIE 1)

En respuesta a la **PIE 1**, los hallazgos sugieren que la deriva conductual cuantificada mediante la puntuación estándar (*Z-score*) de sentimiento **tiende a no operar como el activador principal de la anomalía, sino más bien como un factor confirmador de la intencionalidad**. El análisis mediante valores SHAP indica que las variables de mayor peso discriminante corresponden a las métricas técnicas de hiperactividad (actividad fuera de horario, registros de inicio de sesión, uso de dispositivos USB y acceso masivo a archivos), mientras que el *Z-score* afectivo ocupa una posición intermedia en la jerarquía de contribución del modelo.

Esta distribución de pesos específicos no desestima la hipótesis fundamentada en el procesamiento de lenguaje natural (NLP), sino que delimita su alcance con mayor especificidad: **la métrica afectiva no anticipa de forma directa la anomalía técnica, sino que contribuye a contextualizarla desde una perspectiva motivacional**. Este comportamiento guarda coherencia con los fundamentos del modelo CPIR, donde la acción maliciosa (en este escenario, la exfiltración técnica) constituye el evento terminal, mientras que la deriva afectiva se configura como un precursor observable a lo largo del proceso. En consecuencia, en el diseño de un sistema de alerta temprana, los indicadores basados en el análisis de sentimiento podrían operar como un criterio de priorización o umbral de activación para la investigación analítica, en lugar de constituir una señal primaria de riesgo técnico aislado.

5.2. Limitaciones del AUC como métrica principal (PIE 2)

En respuesta a la **PIE 2**, la divergencia observada entre el AUC global del autocodificador (*autoencoder*, 0.551) y su tasa de captura en el umbral superior (*Recall@Top-K*, 11.52 %) sugiere que los algoritmos no supervisados poseen la capacidad de aislar señales predictivas de interés sin requerir técnicas de sobremuestreo sintético. No obstante, los hallazgos indican que la métrica de evaluación idónea para este escenario difiere del AUC global, configurándose el comportamiento del *recall* en un umbral fijo como un indicador más representativo de la utilidad operativa real en modelos de análisis de comportamiento de usuarios y entidades (UEBA) (Tuor et al., 2017; Wei et al., 2024). Para futuras investigaciones, se plantea la conveniencia de incorporar la curva de precisión-exhaustividad (*Precision-Recall*) como métrica primaria de evaluación.

5.3. Complementariedad algorítmica y sistema de ensamblaje (PIE 3)

En respuesta a la **PIE 3**, el análisis cruzado de las detecciones aporta indicios de una complementariedad funcional y estructurada entre ambos modelos. Mientras que el bosque de aislamiento (*Isolation Forest*) muestra efectividad al aislar anomalías volumétricas evidentes mediante particiones espaciales ortogonales (identificando a 9 actores maliciosos), el modelo basado en aprendizaje profundo (*autoencoder*) destaca en la captura de desviaciones sutiles distribuidas en múltiples dimensiones respecto al patrón de normalidad organizacional, registrando un total de 22 detecciones confirmadas.

La integración de ambas arquitecturas en un sistema de ensamblaje (*ensemble*), fundamentado en la unión lógica de las alertas críticas superiores, permitió elevar la detección global a 24 actores internos (*insiders*) confirmados. Esta sinergia empírica responde a la naturaleza heterogénea y compleja de la amenaza interna: el modelo basado en árboles tiende a identificar alteraciones volumétricas abruptas, mientras que la red neuronal muestra una mayor sensibilidad frente a vectores de riesgo combinados de menor magnitud (tales como la variación simultánea del tono afectivo en las comunicaciones escritas y alteraciones en el horario de actividad). Desde una perspectiva operativa, este enfoque híbrido ofrece una alternativa viable frente al fenómeno de la fatiga de alertas que afecta a los centros de operaciones de seguridad (SOC). Al optimizar la tasa de captura (*recall*) examinando en exclusiva el 0.5 % de la actividad diaria registrada, se aporta evidencia de que es factible incrementar la interceptación de incidentes sin elevar la carga de triaje del analista forense.

5.4. Validación XAI del modelo criminológico CPIR (PIE 4)

En respuesta a la **PIE 4**, la descomposición de las predicciones mediante la librería de interpretabilidad SHAP, aplicada al caso de estudio confirmado MPM0220, sugiere una correspondencia empírica consistente entre las variables matemáticas determinantes y las fases teóricas del modelo *Critical Path to Insider Risk* (CPIR).

El análisis forense mediante técnicas de inteligencia artificial explicable (XAI) indica que la alerta crítica no se activa por un único vector técnico, sino por una secuencia conductual. Las variables operativas con mayor contribución al índice de riesgo (`after_hours_activity`, `total_logon_activity` y `usb_activity_count`) se alinean con las fases de 'preparación activa' y 'explotación de oportunidad' descritas en el modelo CPIR, reflejando el acopio físico y la exfiltración de información en horarios de menor supervisión organizacional.

Asimismo, el peso específico asignado por el algoritmo a la variable `sentiment_z_user` aporta indicios sobre la capacidad del sistema para detectar alteraciones vinculadas al estresor subyacente. Esta desviación afectiva significativa (representada por una puntuación *Z-score* fuertemente negativa) opera como un indicador característico de la fase previa de 'ideación y deterioro', sugiriendo que el modelo es capaz de parametrizar el preludio conductual del incidente técnico. De este modo, las métricas de explicabilidad trascienden la mera auditoría informática, configurándose como un recurso de utilidad para la validación empírica de marcos criminológicos.

5.5. Marco ético, legal y protocolo de actuación

Los resultados obtenidos hacen necesario contextualizar el sistema en su marco normativo y operativo ante cualquier escenario potencial de despliegue real. Esta reflexión complementa la respuesta a la **PIE 4**, al evaluar si el modelo resulta auditable no solo matemáticamente, sino también desde una perspectiva ética y jurídica.

Marco normativo europeo

En el espacio jurídico europeo, cualquier sistema automatizado que procese datos conductuales de empleados con efectos potenciales sobre su situación laboral queda sujeto a marcos normativos de obligado cumplimiento, entre los que destacan:

- **Reglamento General de Protección de Datos (RGPD, Reglamento (UE) 2016/679):** El artículo 22 prohíbe, con carácter general, las decisiones basadas únicamente en el tratamiento automatizado que produzcan efectos jurídicos o afecten significativamente al individuo sin una base legítima, consentimiento explícito o supervisión humana. Por su parte, los artículos 13 y 14 respaldan el derecho del interesado a recibir información clara sobre la lógica algorítmica aplicada. El prototipo desarrollado busca alinearse con este

principio mediante la integración de la capa de explicabilidad (SHAP), proporcionando trazabilidad variable a variable.

- **Ley de Inteligencia Artificial de la UE (AI Act, Reglamento (UE) 2024/1689):** Los sistemas de IA destinados a la evaluación del comportamiento de personas físicas en el ámbito laboral se clasifican como **sistemas de alto riesgo** (Anexo III). Esto conlleva obligaciones estrictas de transparencia, supervisión humana, documentación técnica y registro previo a su puesta en servicio. Al desarrollarse exclusivamente sobre datos sintéticos en un entorno de investigación académica, este proyecto se sitúa fuera del ámbito de aplicación directo del reglamento; no obstante, su arquitectura se plantea bajo principios de conformidad desde el diseño (*compliance by design*).

El principio *Human-in-the-Loop*

El principio rector de cualquier despliegue operativo de este sistema debe fundamentarse en la premisa de que **ninguna decisión con consecuencias laborales para el empleado puede basarse exclusivamente en el resultado directo del modelo**. El sistema se define como una herramienta de **triaje forense preventivo**, y no como un mecanismo de sanción automatizada.

Esta distinción posee implicaciones operativas profundas. El modelo detecta desviaciones estadísticas respecto a la línea base de un usuario, pero no evalúa factores causales ni pondera el contexto personal del empleado. Por lo tanto, no diferencia de forma autónoma entre una exfiltración intencionada y una contingencia de carácter biológico, familiar o profesional que altere transitoriamente el patrón de comportamiento. La limitación de validez ecológica analizada en la sección precedente constituye el fundamento técnico de este principio.

Protocolo de actuación ante una alerta

En un escenario de ejecución real, la activación de una alerta de riesgo crítico por parte del sistema no debe desencadenar una acción punitiva o restrictiva inmediata. El protocolo de actuación propuesto se estructura en tres fases diferenciadas:

1. **Fase de triaje técnico:** el equipo de seguridad analiza la descomposición SHAP de la alerta para determinar qué variables específicas han provocado la desviación y evaluar si el patrón muestra persistencia temporal. Una anomalía aislada presenta un peso diagnóstico significativamente inferior al de una deriva acumulada a lo largo de varias semanas.
2. **Fase de contextualización humana:** el caso se deriva al departamento de **psicología organizacional o bienestar laboral** para realizar una evaluación cualitativa del entorno del empleado. Esta intervención se plantea bajo criterios de confidencialidad y empatía, con el objetivo de determinar si existen estresores legítimos que expliquen la deriva conductual, de forma previa a la consideración de cualquier medida disciplinaria.

3. **Fase de decisión informada:** únicamente si la evaluación cualitativa humana descarta factores contextuales justificantes y la anomalía técnica muestra persistencia, el caso podrá ser derivado a los procedimientos de seguridad corporativa establecidos, bajo una estricta supervisión jurídica y en total conformidad con el marco normativo vigente.

Este protocolo integra el sistema en el marco de la **prevención terciaria** corporativa: se interviene de forma previa a la materialización del daño definitivo, es decir, cuando las acciones de apoyo al empleado son viables y preferibles frente a una respuesta puramente reactiva.

5.6. El rol del *Big Five* en el modelo

La contribución marginal de los rasgos estáticos de personalidad (*Big Five*) en el modelo final merece una reflexión teórica específica. Aunque la literatura criminológica contemporánea sugiere correlaciones entre ciertos perfiles (baja responsabilidad o alto neuroticismo) y el riesgo interno (Nanamou et al., 2024), el algoritmo converge de manera efectiva prescindiendo de dicha información. Desde la perspectiva de la psicología forense y la criminología, este fenómeno no denota una debilidad del enfoque conductual, sino que corrobora la distinción fundamental entre rasgo (estático) y estado (dinámico).

Los hallazgos sugieren que las características innatas de la personalidad operan únicamente como factores distales de predisposición, mientras que la señal verdaderamente predictiva de la amenaza se concentra en los factores proximales de proceso; es decir, en la deriva conductual y afectiva provocada por estresores ambientales observables. Alternativamente, cabe considerar que el tamaño de la muestra de actores internos confirmados (191 sobre 330.452 registros) resulte insuficiente para que el modelo extraiga regularidades estables en dimensiones psicométricas puramente estáticas, una premisa que delimita una línea de investigación complementaria para futuros desarrollos.

5.7. Consideraciones éticas y legales del uso de psicometría organizacional

La utilización de datos psicométricos en el ámbito corporativo está sujeta a un marco normativo estricto que este proyecto ha integrado en su diseño conceptual. En el contexto europeo, el Reglamento General de Protección de Datos (RGPD, Reglamento (UE) 2016/679) clasifica los perfiles de personalidad, sean inferidos o declarados, como categorías de datos sujetas a especial protección cuando se utilizan para la adopción de decisiones automatizadas con efectos jurídicos o significativos sobre el individuo (artículo 22). En consecuencia, el despliegue de modelos basados en el *Big Five* en entornos de ciberseguridad sin una base jurídica legítima o fuera de las garantías explícitas del interesado podría vulnerar dicho marco.

El diseño del presente prototipo mitiga este riesgo normativo mediante tres salvaguardas específicas: (1) las dimensiones psicométricas analizadas proceden del conjunto sintético CERT r4.2 en un entorno controlado de investigación, sin vinculación con personas físicas reales; (2)

tal como reflejan los resultados del análisis SHAP, el sistema no discrimina en función de rasgos estáticos o variables innatas del individuo, sino sobre la base de comportamientos técnicos dinámicos y observables; y (3) la capa de inteligencia artificial explicable (XAI) se alinea con el derecho a la explicación consagrado en los artículos 13 y 14 del RGPD y en los requisitos de transparencia exigidos por la normativa de IA de la UE (*AI Act*, Reglamento (UE) 2024/1689) para sistemas de alto riesgo.

No obstante, ante un escenario de ejecución en un entorno real, se considera imprescindible someter el sistema a una Evaluación de Impacto relativa a la Protección de Datos (EIPD/DPIA), contar con la asesoría obligatoria de un Delegado de Protección de Datos (DPO) y asegurar la participación informada de los comités de representación de los trabajadores. La monitorización preventiva mediante métricas conductuales, desprovista de transparencia o de las debidas garantías jurídicas, constituiría una práctica deontológicamente desaconsejable y restrictiva en el espacio europeo.

Capítulo 6

Conclusiones y trabajos futuros

6.1. Conclusiones

Los resultados obtenidos permiten sostener que el sistema se consolida como un prototipo analítico y funcional evaluado con éxito en un entorno controlado. La investigación aporta indicios verosímiles en torno a la viabilidad de lo que hemos denominado 'la intersección entre la psicología clínica, la criminología y la ciberseguridad'. En primer lugar, se observa que las métricas alcanzadas ofrecen un rendimiento estadísticamente significativo para un modelo de detección no supervisado. Específicamente, la capacidad de aislar a múltiples actores maliciosos examinando únicamente el 0.5 % del volumen total de la actividad corporativa sugiere que **la magnitud de la desviación afectiva aporta una señal crítica al vector de anomalía**. Por lo tanto, el indicador de riesgo más fiable no se halla en el estado emocional absoluto del empleado sino en su 'deriva'. Es decir, **la clave radica en la distancia estadística entre su línea base habitual y su comportamiento actual**.

En síntesis, las cuatro preguntas de investigación planteadas obtienen un sustento empírico coherente en el marco de este prototipo:

- **PIG (Pregunta de Investigación General): Sustentada por la evidencia.** Los datos sugieren la viabilidad de anticipar la amenaza interna mediante una matriz conductual híbrida. El sistema detectó a 24 atacantes confirmados investigando exclusivamente el 0.5 % superior de la actividad registrada.
- **PIE 1 (Psicología y deriva conductual): Sustentada con matices.** La deriva afectiva incrementa la interpretabilidad del sistema y actúa como un confirmador motivacional de la anomalía, aunque los predictores de mayor peso estadístico siguen siendo las variables de hiperactividad técnica. El análisis de sentimiento, por tanto, no sustituye a la señal técnica, sino que la contextualiza.
- **PIE 2 (Desbalanceo extremo): Sustentada por la evidencia.** El enfoque no supervisado sin recurrir a técnicas de sobremuestreo sintético alcanza una tasa de captura (*recall*) del 12.57 % en el umbral crítico del 0.5 %. En términos operativos, esto se traduce

en 24 interceptaciones reales sobre 191 amenazas documentadas, preservando la estructura real del comportamiento organizacional.

- **PIE 3 (Sistema de votación por ensamblaje): Sustentada por la evidencia.** El sistema de ensamblado (*ensemble*) superó el rendimiento de ambos modelos individuales. Esto aporta indicios de que *Isolation Forest* y el autocodificador (*autoencoder*) capturan tipologías de riesgo complementarias y no redundantes.
- **PIE 4 (Explicabilidad y Aplicabilidad Criminológica): Sustentada por la evidencia.** La capa de inteligencia artificial explicable (XAI) tradujo las decisiones matemáticas del modelo en una narrativa forense coherente con las fases del modelo *Critical Path to Insider Risk* (CPIR). De este modo, se proporciona trazabilidad variable a variable y se valida de forma empírica la hipótesis criminológica subyacente del proyecto.

6.2. Logro de los objetivos

Se considera que los objetivos planteados en la fase de conceptualización del proyecto han sido alcanzados de manera satisfactoria. Se ha logrado trasladar el modelo criminológico teórico de la ruta crítica (*Critical Path to Insider Risk*, CPIR) a una formulación matemática y programática ejecutable. Los resultados sugieren que la combinación de variables cuantitativas técnicas con indicadores conductuales dinámicos constituye una estrategia metodológicamente viable, aportando una mayor especificidad analítica frente a los enfoques orientados exclusivamente en la volumetría de red.

6.3. Análisis de planificación y metodología

El desarrollo del proyecto se ha ajustado formalmente a la planificación estratégica original. El paradigma analítico no supervisado se ha constatado como la opción metodológica rigurosa para abordar escenarios caracterizados por un desbalanceo extremo de clases. El principal ajuste incorporado para asegurar la convergencia del trabajo consistió en la integración de modelos de aprendizaje profundo mediante autocodificadores (*autoencoders*) y un sistema de ensamblado (*ensemble*) por unión lógica de alertas. Aunque estas arquitecturas no se habían definido inicialmente como un requisito estricto, resultaron determinantes para incrementar la tasa de captura (*recall*) en el umbral operativo crítico en comparación con el rendimiento del modelo base.

6.4. Impactos éticos, sociales y normativos

Durante la fase de diseño del sistema, se ha priorizado la evaluación del impacto ético y la preservación de la privacidad del usuario. Con el propósito de mitigar el riesgo de sesgo o discriminación algorítmica, así como la generación de falsos positivos que pudieran derivar en medidas organizacionales desproporcionadas, se incorporó un módulo de inteligencia artificial

explicable (XAI). Esta capa promueve la transparencia algorítmica y facilita el ejercicio del derecho a la explicación del interesado. Adicionalmente, el modelo procesa los flujos de comunicaciones escritas abstrayendo exclusivamente una puntuación numérica asociada al estado afectivo, lo que minimiza la necesidad de que los analistas humanos accedan al contenido privado de los correos electrónicos. Bajo esta premisa, el sistema se alinea con los principios de privacidad desde el diseño (*privacy by design*).

Un hallazgo con implicaciones éticas directas corresponde a la contribución marginal observada de los rasgos estáticos de personalidad (*Big Five*) en el vector final de riesgo. El análisis mediante valores SHAP indica que el sistema **no discrimina en función de la identidad o los rasgos innatos del empleado, sino con base en su comportamiento dinámico en relación con su propia línea base histórica**. Esta distinción técnica es la que deslinda un sistema de vigilancia invasiva de un modelo analítico de detección de riesgo operativo, legitimando su consideración potencial en entornos de Recursos Humanos bajo el marco normativo europeo. En consecuencia, el prototipo reacciona ante estresores dinámicos observables y no frente a constructos psicométricos estáticos, reduciendo la introducción de sesgos discriminatorios de difícil detección y corrección en el entorno corporativo.

6.5. Líneas de futuro

Como vías de continuidad y evolución para la presente investigación, se proponen dos ejes estratégicos diferenciados:

1. Mantenimiento operativo, difusión abierta y escalabilidad tecnológica:

A partir de los artefactos funcionales ya consolidados en este proyecto, una línea de desarrollo prioritaria consiste en la migración de este flujo de procesamiento (*pipeline*) estático hacia una arquitectura de procesamiento de datos en flujo continuo (*streaming*), utilizando herramientas como *Apache Kafka*. Esto permitirá la ingesta y puntuación del riesgo en tiempo real, facilitando la intervención preventiva inmediata de los equipos de psicología organizacional. Asimismo, la continuidad del proyecto se apoya en la explotación de los entornos de difusión ya desplegados:

- **Mantenimiento de artefactos en Zenodo:** Los conjuntos de datos derivados (matrices de características conductuales y psicométricas agregadas, anonimizadas y desvinculadas de los datos en bruto del entorno CERT r4.2) se encuentran depositados en la plataforma Zenodo bajo licencia abierta y con un identificador de objeto digital (DOI) persistente (Barrera Mora, 2026). La línea de futuro contempla la actualización periódica de este repositorio a medida que se incorporen nuevas técnicas de filtrado, promoviendo la reproducibilidad independiente y la comparación con investigaciones homólogas.
- **Evolución de la interfaz en Hugging Face Spaces:** El sistema de detección híbrido se encuentra disponible como una aplicación interactiva desarrollada con el entorno *Gradio* en la plataforma Hugging Face Spaces. Actualmente, la interfaz

permite introducir variables de actividad técnica y métricas de sentimiento para obtener la puntuación de anomalía (*anomaly score*) y su correspondiente explicación mediante valores SHAP (gráfico de cascada). Como vía de continuidad, se plantea evaluar la usabilidad de esta herramienta con analistas de seguridad externos para optimizar el diseño de la capa XAI, manteniendo la ejecución en entornos aislados de inferencia estática para salvaguardar el principio de privacidad desde el diseño (*privacy by design*).

2. Incorporación de modelos fundacionales y perfilado dinámico:

Se propone la exploración de modelos de lenguaje de gran escala (LLM) ejecutados en entornos locales (garantizando la estricta confidencialidad de la información corporativa), orientados a extraer un perfilado conductual con mayor nivel de granularidad que el análisis de sentimiento polarizado actual. Esta transición conceptual se desglosa en los ejes de evolución teórica y metodológica que se detallan a continuación.

Líneas de evolución criminológica y psicológica del sistema

El análisis crítico de los resultados y de la literatura científica revela oportunidades de desarrollo para futuras iteraciones del prototipo, orientadas a complementar el alcance del modelo actual:

1. Transición hacia modelos psicométricos dinámicos: alternativas al *Big Five*.

Tal como se argumentó en el análisis de limitaciones, los modelos de personalidad basados en rasgos fijos presentan restricciones de validez ecológica en entornos de seguridad dinámica. Las investigaciones futuras se orientarán hacia marcos psicométricos afines a la criminología corporativa:

- **Modelo HEXACO** (Ashton & Lee, 2007): incorpora la dimensión Honestidad-Humildad, identificada en la literatura como un predictor de interés en delitos de cuello blanco y fraude organizacional, escenarios directamente vinculados con la amenaza interna.
- **Tríada Oscura** (Paulhus & Williams, 2002): los constructos de maquiavelismo, narcisismo y psicopatía subclínica constituyen un marco de referencia en criminología forense para el análisis del comportamiento transgresor en entornos corporativos, evaluando disposiciones orientadas a la vulneración normativial en lugar de rasgos de personalidad adaptativa.

Ambos marcos teóricos comparten una distinción conceptual que el *Big Five* no aborda de forma directa: la separación entre rasgo (disposición estable) y estado (condición dinámica situacional). La amenaza interna se manifiesta fundamentalmente como un fenómeno de estado; el actor no ejecuta la acción maliciosa por la mera presencia de un rasgo estático, sino debido a un proceso de deterioro relacional con la organización que el modelo CPIR describe de forma progresiva. Los desarrollos futuros buscarán parametrizar esta dimensión temporal.

2. Integración de la Teoría de los Marcos Relacionales (RFT) en el módulo NLP.

El análisis de sentimiento basado en polaridad léxica ofrece eficiencia operativa, pero presenta limitaciones en la captura de estructuras cognitivas complejas. Se propone la evolución del módulo de procesamiento de lenguaje natural hacia arquitecturas basadas en modelos de lenguaje ejecutados localmente y fundamentadas en la Teoría de los Marcos Relacionales (Hayes et al., 2001, 2016), marco de referencia de la Terapia de Aceptación y Compromiso (ACT). Aplicada al análisis de textos corporativos, la RFT permitiría inferir la forma en que el empleado enmarca cognitivamente su relación de identidad con la institución, evaluando patrones de alienación progresiva ('nosotros frente a ellos'), disonancias entre el esfuerzo percibido y el reconocimiento obtenido, o la erosión del compromiso organizacional. Estos constructos teórico-clínicos se corresponden de forma precisa con la fase de ideación descrita en el modelo CPIR.

3. Inclusión de variables de contexto organizacional (*macro-estresores*).

El prototipo actual evalúa las desviaciones del individuo de forma independiente al entorno macro-organizacional. Una evolución metodológica relevante consistirá en la integración de variables procedentes de los registros de Recursos Humanos como moduladores temporales de la tasa de riesgo: denegaciones de promoción, procesos de reestructuración departamental, modificaciones en la línea de supervisión directa o la existencia de expedientes administrativos. Estos eventos operarán como estresores contextuales con marca temporal, facilitando la interpretación de una anomalía técnica no como un suceso aislado, sino como una potencial reacción conductual a un estímulo externo identificable.

4. Diseño de un marco de triaje conductual y arquitectura de intervención humanizada.

El desarrollo de soluciones predictivas en ciberseguridad conductual debe converger en una arquitectura operativa que delimite con rigor tres esferas de actuación diferenciadas, de conformidad con los principios del marco normativo europeo:

- **La esfera de seguridad:** el sistema automatizado identifica la anomalía técnica y conductual y genera una alerta de triaje. No emite diagnósticos clínicos, no ejecuta sanciones ni accede a datos protegidos de salud.
- **La esfera de bienestar organizacional:** las alertas que superan el umbral crítico actúan exclusivamente como indicadores de derivación preventiva hacia un Programa de Asistencia al Empleado (*Employee Assistance Program*, EAP), donde profesionales independientes pueden realizar evaluaciones cualitativas o intervenciones de apoyo bajo un estricto secreto profesional.
- **La esfera clínica:** completamente disociada de las estructuras de seguridad y control corporativo. En el marco del RGPD (artículo 9), las métricas relativas a la salud mental constituyen categorías especiales de datos cuyo consentimiento en el ámbito laboral se encuentra comprometido por la asimetría inherente a la relación contractual. El único flujo de información admisible hacia la organización consistirá en un dictamen binario de aptitud laboral, garantizando la confidencialidad del proceso.

Este diseño conceptual configura al sistema de inteligencia artificial como un mecanismo indicador de activación temprana y no como un entorno de vigilancia punitiva. La respuesta resultante se orienta a la prevención y el soporte institucional, en alineación con los principios del Metacódigo Ético de la EFPA y las directrices de transparencia de la Ley de Inteligencia Artificial de la Unión Europea.

Capítulo 7

Glosario

- **ACT (*Acceptance and Commitment Therapy* / Terapia de Aceptación y Compromiso):**

Modelo psicoterapéutico de tercera generación desarrollado por Steven Hayes y colaboradores, fundamentado en la Teoría de los Marcos Relacionales (RFT). A diferencia de las terapias cognitivas clásicas, la ACT no persigue la eliminación del pensamiento negativo sino el desarrollo de la flexibilidad psicológica: la capacidad del individuo de contactar con el momento presente y actuar conforme a sus valores incluso en presencia de malestar emocional. En el contexto organizacional, la ACT se aplica en programas de bienestar laboral (EAP) como herramienta de intervención ante estresores como el agotamiento profesional, el agravio percibido o la desconexión con el rol. En este proyecto se referencia como el modelo terapéutico idóneo para la intervención clínica posterior a una alerta del sistema, ejecutada bajo secreto profesional y completamente desconectada de la esfera de seguridad corporativa.

- **AI Act (Reglamento de Inteligencia Artificial de la UE, 2024/1689):**

Marco regulatorio europeo que clasifica los sistemas de inteligencia artificial según su nivel de riesgo y establece obligaciones proporcionales para cada categoría. Los sistemas que evalúan el comportamiento de personas físicas en el ámbito laboral están clasificados como **sistemas de alto riesgo** (Anexo III), lo que implica requisitos de transparencia, supervisión humana, documentación técnica auditada y registro en la base de datos europea antes de su puesta en servicio. El sistema desarrollado en este proyecto opera exclusivamente sobre datos sintéticos en un entorno académico, quedando fuera del ámbito de aplicación directo; no obstante, su arquitectura ha sido diseñada para ser compatible con estos requisitos desde el origen (*compliance by design*).

- **AUC-ROC (*Area Under the ROC Curve* / Área Bajo la Curva ROC):**

Métrica estadística que cuantifica la capacidad discriminante global de un modelo de clasificación. Representa el área bajo la curva que traza la Tasa de Captura (*TPR*) frente a la Tasa de Falsos Positivos (*FPR*) a lo largo de todos los umbrales de decisión posibles. Un valor de 1.0 indica discriminación perfecta; un valor de 0.5 equivale a una predicción

aleatoria (lanzar una moneda). En contextos de desbalanceo extremo (como la detección de amenazas internas, donde los atacantes representan una fracción mínima del total) el AUC puede ser engañosamente alto o bajo sin reflejar la utilidad operativa real del modelo.

- **Autocodificador (*Autoencoder*):**

Arquitectura de red neuronal profunda diseñada para el aprendizaje de representaciones comprimidas de los datos de entrada. Consta de dos componentes: un *encoder* que comprime la información en un espacio latente de menor dimensión (“cuello de botella”), y un *decoder* que intenta reconstruir la entrada original a partir de esa representación comprimida. En detección de anomalías, la premisa es que un Autoencoder entrenado sobre comportamiento normal aprende a reconstruir con precisión dicho comportamiento. Al procesar un perfil atípico, la reconstrucción fracasa, generando un **Error de Reconstrucción** (*MSE*) elevado que actúa como puntuación de riesgo.

- **Big Five (Modelo de personalidad de los ‘Cinco Grandes’ / OCEAN):**

Marco psicométrico de referencia en psicología diferencial y organizacional que describe la personalidad humana en cinco dimensiones independientes: **O**penness (Apertura a la experiencia), **C**onscientiousness (Responsabilidad o escrupulosidad), **E**xtraversion (Extraversión), **A**greeableness (Amabilidad) y **N**euroticism (Neuroticismo). Desarrollado a partir de los trabajos de McCrae y Costa (1987) y ampliamente validado transculturalmente, el modelo mide rasgos de personalidad **estáticos y disposicionales** que permanecen relativamente estables a lo largo del tiempo. En el contexto de este proyecto, los rasgos Big Five se incorporaron como variables de personalidad de base por usuario, si bien el análisis SHAP demostró empíricamente que su contribución discriminante en el modelo final es marginal, lo cual es coherente con la literatura: la amenaza interna no emerge de quién *es* el empleado, sino de cómo *está actuando* respecto a su propia línea base.

- **Contaminación (contamination):**

Hiperparámetro del algoritmo *Isolation Forest* que estima la proporción esperada de anomalías en el conjunto de datos. Controla directamente el umbral de decisión del modelo: un valor de 0.005 significa que el modelo etiquetará como anómalos únicamente el 0.5 % de los registros con menor puntuación. En el contexto de ciberseguridad, este parámetro es crítico para el equilibrio entre *Recall* (captura de atacantes) y Precisión (reducción de falsos positivos), y su ajuste debe fundamentarse en el coste operativo de las investigaciones del equipo de seguridad.

- ***Compliance by Design*:**

Principio de diseño de sistemas tecnológicos por el cual los requisitos normativos y éticos (privacidad, transparencia, supervisión humana) se incorporan como restricciones de arquitectura desde las fases iniciales del desarrollo, en lugar de añadirse como capas de

mitigación a posteriori. Concepto análogo y complementario al de *Privacy by Design*, específicamente orientado al cumplimiento regulatorio proactivo.

- **CPIR (*Critical Path to Insider Risk*):**

Modelo teórico y criminológico desarrollado por Shaw y Sellers (2015) que describe las fases secuenciales que atraviesa un empleado desde la aparición de un estresor personal o profesional hasta la comisión de un acto hostil contra la organización. Las fases incluyen: predisposición (rasgos psicológicos de base), estresor desencadenante, ideación (plan cognitivo), búsqueda de oportunidad, preparación activa y acción maliciosa. La duración media del proceso de incubación se estima en 73 días antes del incidente técnico.

- **CRISP-DM (*Cross-Industry Standard Process for Data Mining*):**

Metodología estándar para la gestión de proyectos de ciencia de datos y minería de información. Define un ciclo de vida iterativo compuesto por seis fases: comprensión del negocio, comprensión de los datos, preparación de los datos, modelado, evaluación y despliegue. Su carácter cíclico permite revisar y ajustar decisiones anteriores a medida que emerge nuevo conocimiento en fases posteriores.

- **Deriva Conductual (*Behavioral Drift*):**

Fluctuación o cambio anómalo y progresivo en los patrones de comportamiento y comunicación de un usuario respecto a su propia línea base histórica. Componente central del modelo CPIR, la deriva conductual constituye el período observable entre el inicio del estresor y la materialización del acto maliciosa. Su cuantificación estadística mediante métricas como el *Z-Score* de sentimiento es el principal mecanismo de alerta temprana del sistema desarrollado en este proyecto.

- **EAP (*Employee Assistance Program* / Programa de Asistencia al Empleado):**

Servicio de bienestar organizacional, generalmente externalizado y gestionado por profesionales clínicos independientes, que ofrece apoyo psicológico, social y legal a los empleados de forma confidencial. La confidencialidad es estructural: el EAP opera bajo secreto profesional estricto y el único flujo de información admisible hacia la empresa es un veredicto binario de aptitud laboral, sin contenido clínico. En el marco de intervención propuesto en este proyecto, el EAP es el destinatario natural de las derivaciones generadas por una alerta de alto riesgo del sistema, actuando como cortafuegos (*firewall*) entre la inteligencia de seguridad y la intervención de salud mental.

- **HEXACO:**

Modelo de personalidad de seis factores desarrollado por Ashton y Lee (2007) como extensión del *Big Five*. Añade una sexta dimensión (**Honestidad-Humildad**) que captura la tendencia del individuo a evitar la manipulación, el engaño y la explotación de otros en beneficio propio. Esta dimensión, ausente en el modelo OCEAN es especialmente predictiva en contextos de fraude organizacional y delincuencia de cuello blanco, lo que convierte al HEXACO en un marco psicométrico más adecuado que el *Big Five* para la investigación futura en detección de amenaza interna.

- ***Human-in-the-Loop* (Humano en el Bucle):**

Principio de diseño de sistemas de inteligencia artificial que establece la supervisión humana como requisito irrenunciable en cualquier proceso de toma de decisiones con consecuencias para personas físicas. En el contexto de este proyecto, implica que el *output* del sistema de 'Puntuación de anomalía' (o *Anomaly Score* y el veredicto del ensamblaje o *Ensemble*) es una señal de triaje, no una decisión ejecutable de forma autónoma. Toda alerta de alto riesgo requiere revisión y contextualización por parte de un analista humano cualificado antes de desencadenar cualquier acción sobre el empleado afectado. Este principio está explícitamente recogido en el *AI Act* como requisito para sistemas de alto riesgo.

- ***Fuga de Datos* (*Data Leakage*):**

Error metodológico crítico en el entrenamiento de modelos predictivos mediante el cual se incluye información del futuro (o de la variable objetivo) en el conjunto de entrenamiento, produciendo estimaciones de rendimiento artificialmente optimistas e invalidando la capacidad de generalización del modelo. En este proyecto se previno mediante el uso de ventanas móviles históricas desplazadas (*shift(1)*), garantizando que el estado emocional de referencia de un usuario solo incluye datos de períodos estrictamente anteriores al punto de predicción.

- ***Amenaza Interna* (*Insider Threat*):**

Riesgo de seguridad originado por individuos con acceso legítimo a los activos, sistemas e información de una organización (empleados activos, ex-empleados, contratistas o socios) que utilizan dicho acceso con fines maliciosos o por negligencia. A diferencia de las amenazas externas, el atacante interno no necesita vulnerar el perímetro de seguridad, lo que dificulta su detección mediante herramientas de ciberseguridad tradicionales.

- ***Isolation Forest* (*Bosque de Aislamiento*):**

Algoritmo de detección de anomalías no supervisado propuesto por Liu et al. (2008). Se basa en la premisa de que las anomalías son estadísticamente "pocas y distintas", lo que las hace susceptibles de ser aisladas mediante un número reducido de particiones binarias aleatorias del espacio de características. El algoritmo construye un conjunto (*ensemble*) de árboles de decisión aleatorios; la profundidad media a la que un punto queda aislado en todos los árboles es inversamente proporcional a su puntuación de normalidad: los puntos anómalos se aíslan en ramas superficiales, mientras que los normales requieren muchas particiones. Su principal ventaja es la eficiencia computacional sobre conjuntos de datos de alta dimensionalidad.

- ***LDAP* (*Lightweight Directory Access Protocol*):**

Protocolo estándar de red utilizado para acceder y mantener servicios de directorio distribuidos. En el contexto corporativo, LDAP gestiona la información de usuarios (nombre,

departamento, puesto, fecha de inicio, estado laboral), constituyendo la fuente de metadatos organizacionales que enriquece el perfilado de los empleados en el sistema de detección.

- **Macro-estresores organizacionales:**

Eventos críticos en la dinámica de una organización que funcionan como estímulos desencadenantes de deterioro conductual en el marco del modelo CPIR: denegaciones de ascenso, reestructuraciones departamentales, cambios de responsable directo, conflictos disciplinarios o reducciones salariales. A diferencia de los estresores individuales (de naturaleza privada e inobservable por el sistema), los macro-estresores organizacionales son eventos registrables con marca temporal en los sistemas de Recursos Humanos, lo que los convierte en variables contextuales inyectables en el modelo para mejorar la interpretabilidad de las anomalías detectadas.

- **EFPA (Meta-código Ético de la Federación Europea de Asociaciones de Psicólogos):**

Marco deontológico de referencia para el ejercicio profesional de la psicología en Europa. Establece cuatro principios fundamentales: respeto a los derechos y dignidad de las personas, competencia profesional, responsabilidad y honestidad. En el contexto de este proyecto, el Meta-código de la EFPA fundamenta el principio de que ninguna decisión con consecuencias para el empleado puede basarse exclusivamente en el *output* de un modelo algorítmico, y que la intervención clínica derivada de una alerta debe realizarse bajo las garantías deontológicas del secreto profesional.

- **MICE (*Money, Ideology, Coercion, Ego*):**

Acrónimo utilizado en el ámbito de la inteligencia y la contrainteligencia para categorizar las motivaciones primarias de los individuos que comprometen información confidencial. Proporciona un marco de clasificación motivacional para el perfilado del atacante interno: **Money** (motivación económica o financiera), **Ideology** (motivación ideológica o política), **Coercion** (motivación por coacción o chantaje) y **Ego** (motivación por orgullo, reconocimiento o venganza).

- **MSE (*Mean Squared Error* / Error Cuadrático Medio):**

Función de pérdida que mide la media de los cuadrados de las diferencias entre los valores predichos por un modelo y los valores reales. En el contexto del Autoencoder, el MSE cuantifica la incapacidad del modelo para reconstruir fielmente un perfil de actividad dado: un MSE elevado indica que ese perfil se desvía significativamente de los patrones aprendidos como normales, siendo utilizado directamente como 'Puntuación de anomalía'.

- **NLP (*Natural Language Processing* / Procesamiento de Lenguaje Natural):**

Subárea de la inteligencia artificial y la lingüística computacional dedicada al procesamiento, comprensión y generación automatizada del lenguaje humano en formato textual

o hablado. En este proyecto se aplica para extraer indicadores de sentimiento cuantificables a partir del contenido textual de comunicaciones internas corporativas, utilizando el analizador VADER.

- **Oversampling / Sobremuestreo:**

Técnica de preprocesamiento de datos utilizada para abordar el problema del desbalanceo de clases en aprendizaje supervisado. Consiste en incrementar artificialmente el número de muestras de la clase minoritaria mediante generación sintética (e.g., SMOTE, ADASYN). En este proyecto fue **descartado metodológicamente** por el riesgo de distorsionar la estructura real del comportamiento organizacional al generar eventos maliciosos sintéticos que no reflejan la dinámica genuina del atacante.

- **Precisión (*Precision*):**

Proporción de alertas positivas emitidas por el modelo que corresponden a eventos verdaderamente anómalos, sobre el total de alertas emitidas. Mide la fiabilidad de cada alerta individual: una precisión alta implica menos falsas alarmas. En el contexto operativo de ciberseguridad, la precisión determina directamente la carga de trabajo del equipo de seguridad.

- **Recall (Tasa de Captura / *True Positive Rate*):**

Proporción de eventos anómalos o atacantes reales correctamente identificados por el modelo, sobre el total de eventos anómalos existentes. En detección de amenazas internas, el Recall es la métrica operativamente crítica: un Recall bajo significa que atacantes reales escapan al sistema. El *trade-off* entre *Recall* y Precisión se gestiona mediante el ajuste del umbral de decisión del modelo.

- **Recall @ Top-K:**

Variante focalizada del *Recall* que mide la proporción de atacantes reales capturados dentro de los K eventos de mayor puntuación de riesgo emitidos por el modelo. Es la métrica más representativa de la utilidad operativa real en sistemas UEBA, donde la restricción de investigar solo un porcentaje reducido del total de actividad (e.g., el 0.5 %) impone un límite fijo de K alertas.

- **Rasgo vs. Estado (*Trait vs. State*):**

Distinción fundamental en psicología diferencial. Un **rasgo** es una disposición estable de la personalidad que permanece relativamente constante a lo largo del tiempo y las situaciones (e.g., las dimensiones del *Big Five*). Un **estado** es una condición psicológica transitoria y situacionalmente determinada (e.g., la hostilidad reactiva ante un agravio laboral). La amenaza interna es un fenómeno de **estado**, no de rasgo: el atacante no exfiltra datos porque tenga una puntuación baja en Amabilidad, sino porque atraviesa una fase dinámica de deterioro relacional con la organización. Esta distinción justifica tanto las limitaciones del *Big Five* como la superioridad operativa de métricas dinámicas como el *Z-Score* de sentimiento para la detección temprana.

- **RFT (Teoría de los Marcos Relacionales / *Relational Frame Theory*):**

Marco teórico en psicología del lenguaje y la cognición desarrollado por Hayes y colaboradores (2001), que constituye la base científica de la ACT. La RFT postula que el comportamiento humano complejo está mediado por redes de relaciones simbólicas aprendidas (marcos relacionales) que determinan cómo el individuo interpreta su entorno y regula su conducta. Aplicada al análisis de texto corporativo, la RFT ofrece un marco para ir más allá de la polaridad léxica e inferir cómo el empleado enmarca cognitivamente su relación con la organización: patrones de alienación progresiva (“nosotros vs. ellos”), disonancia entre esfuerzo percibido y reconocimiento recibido, o erosión del compromiso. Estos constructos se corresponden con la fase de ideación del modelo CPIR y representan la evolución natural del módulo NLP del sistema en futuras iteraciones.

- **Tríada Oscura (*Dark Triad*):**

Constructo psicológico que agrupa tres rasgos de personalidad subclínicos (Narcisismo, Maquiavelismo y Psicopatía) identificados por Paulhus y Williams (2002) como predictores de comportamiento antisocial en contextos normativos. A diferencia de los trastornos clínicos formales, los rasgos de la Tríada Oscura se distribuyen en la población general de forma dimensional y son especialmente relevantes en perfiles de delincuencia corporativa: el individuo con puntuaciones elevadas tiende a la manipulación instrumental, la ausencia de empatía y la disposición a transgredir normas cuando el beneficio percibido supera el riesgo de detección. Constituye el marco psicométrico de referencia en criminología forense para el perfil del atacante interno motivado por ego o venganza (categorías del modelo MICE).

- ***Tripwire* (Cable Trampa):**

Metáfora operativa empleada en ciberseguridad y en este proyecto para describir la función del sistema de detección: un mecanismo de activación temprana que detecta la anomalía conductual y desencadena una respuesta humana, sin ejecutar ninguna acción autónoma sobre el individuo. La imagen es deliberada: el *tripwire* no atrapa ni sanciona, simplemente alerta de que algo ha cruzado un umbral que merece atención. En el contexto del Marco de Triage Conductual propuesto, la respuesta desencadenada es siempre una derivación preventiva a bienestar organizacional, nunca una acción punitiva automatizada.

- **SHAP (*SHapley Additive exPlanations*):**

Método basado en la Teoría de Juegos cooperativos (Shapley, 1953) utilizado para aumentar la transparencia de los modelos de *Machine Learning*, asignando a cada variable su contribución exacta y marginal a la predicción final. Garantiza tres propiedades matemáticas esenciales para contextos forenses: eficiencia (las contribuciones suman exactamente la diferencia entre la predicción individual y el valor base), simetría y linealidad. Permite auditar las decisiones del modelo variable a variable, tanto a nivel local (caso individual) como global (comportamiento sistemático del modelo).

- **SIEM (*Security Information and Event Management*):**

Plataforma tecnológica que centraliza la recopilación, correlación y análisis de eventos de seguridad en tiempo real procedentes de múltiples fuentes de una infraestructura de TI (servidores, *firewalls*, *endpoints*, etc.). Opera mediante reglas estáticas y heurísticas predefinidas. Su principal limitación frente al atacante interno es la incapacidad de detectar comportamientos anómalos que no violen ninguna regla preestablecida, al utilizar credenciales legítimas.

- **Sobreajuste (*Overfitting*):**

Fenómeno por el cual un modelo de aprendizaje automático aprende con excesiva especificidad las particularidades del conjunto de entrenamiento, incluyendo el ruido aleatorio, perdiendo su capacidad de generalización a datos nuevos no vistos. En el Autoencoder desarrollado en este proyecto se mitigó mediante capas *Dropout* y monitorización de la pérdida de validación.

- **UEBA (*User and Entity Behavior Analytics*):**

Paradigma de ciberseguridad que abandona la búsqueda de “firmas” de amenazas conocidas en favor de la creación de una línea base dinámica del comportamiento normal de cada usuario y entidad (dispositivo, servidor, etc.). Las desviaciones estadísticamente significativas respecto a esa línea base individual generan alertas de riesgo, independientemente de si el comportamiento viola alguna regla técnica establecida.

- **VADER (*Valence Aware Dictionary and sEntiment Reasoner*):**

Herramienta de análisis de sentimiento basada en un léxico de reglas diseñada específicamente para texto en redes sociales y comunicaciones informales en inglés. Proporciona cuatro puntuaciones: *positive*, *negative*, *neutral* y *compound* (índice normalizado entre -1 y +1 que resume la valencia global del texto). Su principal ventaja es la ausencia de necesidad de entrenamiento supervisado, lo que la hace aplicable en contextos donde no se dispone de datos etiquetados.

- **Validez Ecológica:**

Criterio metodológico que evalúa el grado en que los resultados obtenidos en un entorno controlado o simulado son representativos y generalizables a los comportamientos y situaciones de la vida real. No es un atributo binario sino un continuo: cuanto más artificiales son las condiciones de producción de los datos, menor es la confianza en que las relaciones estadísticas detectadas reflejen dinámicas genuinas del comportamiento humano fuera del entorno simulado. En este proyecto, la validez ecológica del conjunto de datos CERT r4.2 está comprometida por el sistema de mapeado técnico-psicométrico empleado en su construcción, lo que limita la generalización de los resultados a escenarios reales y orienta el trabajo futuro hacia la validación sobre datos organizacionales auténticos.

- **Z-Score (Puntuación Estándar):**

Medida estadística que indica cuántas desviaciones estándar un dato específico se encuentra por encima o por debajo de la media de su grupo de referencia. En este proyecto se

aplica de forma **intrasujeto**: el *Z-Score* de sentimiento de un usuario compara su estado afectivo actual con su propia media histórica, no con la media de la organización. Esta implementación personalizada evita la comparación interpersonal y garantiza que el sistema detecte la *deriva individual*, no la diferencia respecto a un estándar colectivo.

Capítulo 8

Bibliografía

- Abadi, M., Agarwal, A., Barham, P., Brevdo, E., Chen, Z., Citro, C., Corrado, G., Davis, A., Dean, J., Devin, M., Ghemawat, S., Goodfellow, I., Harp, A., Irving, G., Isard, M., Jia, Y., Jozefowicz, R., Kaiser, L., Kudlur, M., ... Zheng, X. (2015). *TensorFlow: Large-Scale Machine Learning on Heterogeneous Systems*. <https://www.tensorflow.org/>
- Abiola, O., Abayomi-Alli, A., Tale, O. A., Misra, S., & Abayomi-Alli, O. (2023). Sentiment analysis of COVID-19 tweets from selected hashtags in Nigeria using VADER and TextBlob analyser. *Journal of Electrical Systems and Information Technology*, 10(1), 5. <https://doi.org/10.1186/s43067-023-00070-9>
- Al-Mhiqani, M. N., Ahmad, R., Zainal Abidin, Z., Yassin, W., Hassan, A., Abdulkareem, K. H., Ali, N. S., & Yunus, Z. (2020). A review of insider threat detection: Classification, machine learning techniques, datasets, open challenges, and recommendations. *Applied Sciences*, 10(15), 5208. <https://doi.org/10.3390/app10155208>
- American Psychological Association (APA). (2017). *Ethical Principles of Psychologists and Code of Conduct*. <https://www.apa.org/ethics/code/>
- Asad Hasan. (s. f.). *Processed_CERT_Insider_Threat_dataset_using-CTI-framework* [Dataset]. IEEE DataPort. <https://doi.org/10.21227/TGSH-4409>
- Ashton, M. C., & Lee, K. (2007). Empirical, theoretical, and practical advantages of the HEXACO model of personality structure. *Personality and Social Psychology Review*, 11(2), 150–166. <https://doi.org/10.1177/1088868306294907>
- Barrera Mora, A. (2026). *Behavioral and Psychometric Feature Matrix for Insider Threat Detection (Derived from CERT r4.2) (1.0.0)* [Data set]. Zenodo. <https://doi.org/10.5281/zenodo.19435851>
- Basu, S., Victoria Chua, Y. H., Wah Lee, M., Lim, W. G., Maszczyk, T., Guo, Z., & Dauwels, J. (2018). Towards a data-driven behavioral approach to prediction of insider-threat. *2018 IEEE International Conference on Big Data (Big Data)*, 4994–5001. <https://doi.org/10.1109/BigData.2018.8622529>

- Bell, A. J., Rogers, M. B., & Pearce, J. M. (2019). The insider threat: Behavioral indicators and factors influencing likelihood of intervention. *International Journal of Critical Infrastructure Protection*, 24, 166–176. <https://doi.org/10.1016/j.ijcip.2018.12.001>
- BobSulli. (2023). Cost Of Insider Risks Global Report 2023. *Ponemon-Sullivan Privacy Report*. <https://ponemonsullivanreport.com/2023/10/cost-of-insider-risks-global-report->
- Bronfenbrenner, U. (1977). Toward an experimental ecology of human development. *American psychologist*, 32(7), 513.
- California Consumer Privacy Act of 2018 (CCPA), Cal. Civ. Code § 1798.100 et seq. <https://oag.ca.gov/privacy/ccpa>
- Cressey, D. R. (1973). *Other people's money: A study in the social psychology of embezzlement*. Patterson Smith.
- European Federation of Psychologists' Associations (EFPA). (2005). *Meta-code of Ethics*. <https://www.efpa.eu/sites/default/files/2023-04/meta-code-of-ethics.pdf>
- Fayyad, D. (2025). Measuring the human risk factor: Developing predictive models for insider threat detection using behavioral analytics. *International Journal of Humanities and Information Technology*, 7(4), 29–40.
- Glasser, J., & Lindauer, B. (2013). Bridging the gap: A pragmatic approach to generating insider threat data. *IEEE Security and Privacy Workshops*, 98–104. <https://doi.org/10.1109/SPW.2013.37>
- Greitzer, F. L., & Frincke, D. A. (2010). Combining traditional cyber security audit data with psychosocial data: Towards predictive modeling for insider threat mitigation. En *Insider threats in cyber security* (pp. 85–113). Springer.
- Greitzer, F. L., Kangas, L. J., Noonan, C. F., Brown, C. R., & Ferryman, T. (2013). Psychosocial modeling of insider threat risk based on behavioral and word use analysis. *e-Service Journal*, 9(1), 106–138.
- Greitzer, F. L., Kangas, L. J., Noonan, C. F., Dalton, A. C., & Hohimer, R. E. (2012). Identifying at-risk employees: Modeling psychosocial precursors of potential insider threats. *Proceedings of the 45th Hawaii International Conference on System Sciences*, 2392–2401. <https://doi.org/10.1109/HICSS.2012.309>
- Hayes, S. C., Barnes-Holmes, D., & Roche, B. (Eds.). (2001). *Relational frame theory: A post-Skinnerian account of human language and cognition*. Kluwer Academic/Plenum Publishers.
- Hayes, S. C., Strosahl, K. D., & Wilson, K. G. (2001). *Acceptance and Commitment Therapy: An experiential approach to behavior change*. Guilford Press.

- Haq, M. A., & Alshehri, M. (2022). Insider threat detection based on NLP word embedding and machine learning. *Intelligent Automation and Soft Computing*, 33, 619–635. <https://doi.org/10.32604/iasc.2022.021430>
- Hutto, C., & Gilbert, E. (2014). VADER: A parsimonious rule-based model for sentiment analysis of social media text. *Proceedings of the 8th International AAAI Conference on Weblogs and Social Media (ICWSM-14)*, 8(1), 216–225.
- Idensohn, C. J., & Flowerday, S. (2024). Malicious insider behaviour in cybersecurity informed by the Fraud Triangle. *Journal of Information Systems Security*, 22.
- Jiang, W., Tian, Y., Liu, W., & Liu, W. (2018). An insider threat detection method based on user behavior analysis. En *International Conference on Security, Privacy and Anonymity in Computation, Communication and Storage* (pp. 421–431). Springer. https://doi.org/10.1007/978-3-030-00828-4_43
- Khan, M. Z. A., & Arshad, J. (2022). Anomaly detection and enterprise security using user and entity behavior analytics (UEBA). *IEEE*, 1–9.
- Kim, J., Park, M., Kim, H., Cho, S., & Kang, P. (2019). Insider threat detection based on user behavior modeling and anomaly detection algorithms. *Applied Sciences*, 9(19), 4018. <https://doi.org/10.3390/app9194018>
- Krishnaraja, K., & Moorthy, G. K. (2023). Big 5 personality traits and machine learning: A combined approach for classifying malicious insiders. *Journal of Technical Education*, 20, 20.
- Le, D. C., Zincir-Heywood, N., & Heywood, M. I. (2020). Analyzing data granularity levels for insider threat detection using machine learning. *IEEE Transactions on Network and Service Management*, 17(1), 30–44. <https://doi.org/10.1109/TNSM.2020.2967721>
- Lindauer, B., Glässer, J., Rosen, M., Wallnau, K., & Moore, A. (2014). *Insider Threat Test Dataset* (CERT r4.2) [Dataset]. Software Engineering Institute, Carnegie Mellon University. <https://www.sei.cmu.edu/library/insider-threat-test-dataset/>
- Liu, F. T., Ting, K. M., & Zhou, Z. H. (2008). Isolation Forest. *2008 Eighth IEEE International Conference on Data Mining*, 413–422. <https://doi.org/10.1109/ICDM.2008.17>
- Lundberg, S. M., & Lee, S. I. (2017). A unified approach to interpreting model predictions. *Advances in Neural Information Processing Systems*, 30, 4765–4774.
- McCrae, R. R., & Costa, P. T. (1987). Validation of the five-factor model of personality across instruments and observers. *Journal of Personality and Social Psychology*, 52(1), 81–90. <https://doi.org/10.1037/0022-3514.52.1.81>
- Mittal, A., & Garg, U. (2022). A proposed approach to analyze insider threat detection using emails. *2022 International Conference on Computer Communication and Informatics (ICCCI)*, 1–6.

- Mladenovic, D., Antonijevic, M., Jovanovic, L., Simic, V., Zivkovic, M., Bacanin, N., Zivkovic, T., & Perisic, J. (2024). Sentiment classification for insider threat identification using metaheuristic optimized machine learning classifiers. *Scientific Reports*, 14, 25731. <https://doi.org/10.1038/s41598-024-77240-w>
- Mosca, E., Szigeti, F., Tragianni, S., Gallagher, D., & Groh, G. (2022). SHAP-based explanation methods: A review for NLP interpretability. *Proceedings of the 29th International Conference on Computational Linguistics*, 4593–4603.
- Nanamou, N. K., Neal, C., Boulahia-Cuppens, N., Cuppens, F., & Bkakria, A. (2024). From traits to threats: Learning risk indicators of malicious insider using psychometric data. https://doi.org/10.1007/978-3-031-80020-7_10
- Ohu, F., & Jones, L. A. (2025). Predictive behavioral risk intelligence: An AI framework for insider threat detection based on cognitive and psychological indicators. *RAIS Journal for Social Sciences*, 9(2), 108–132.
- Paulhus, D. L., & Williams, K. M. (2002). The Dark Triad of personality: Narcissism, Machiavellianism, and psychopathy. *Journal of Research in Personality*, 36(6), 556–568. [https://doi.org/10.1016/S0092-6566\(02\)00505-6](https://doi.org/10.1016/S0092-6566(02)00505-6)
- Paxton-Fear, K. (2021). *Understanding insider threats using natural language processing* [Tesis doctoral]. University of Oxford.
- Pedregosa, F., Varoquaux, G., Gramfort, A., Michel, V., Thirion, B., Grisel, O., Blondel, M., Prettenhofer, P., Weiss, R., Dubourg, V., Vanderplas, J., Passos, A., Cournapeau, D., Brucher, M., Perrot, M., & Duchesnay, É. (2011). Scikit-learn: Machine learning in Python. *Journal of Machine Learning Research*, 12, 2825–2830.
- Ponce-Bobadilla, A. V., Schmitt, V., Maier, C. S., Mensing, S., & Stodtmann, S. (2024). Practical guide to SHAP analysis: Explaining supervised machine learning model predictions in drug development. *Clinical and Translational Science*, 17(11), e70056. <https://doi.org/10.1111/cts.70056>
- Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos). *Diario Oficial de la Unión Europea*, L 119, 1-88.
- Reglamento (UE) 2024/1689 del Parlamento Europeo y del Consejo, de 13 de junio de 2024, por el que se establecen normas armonizadas sobre inteligencia artificial (Ley de Inteligencia Artificial). *Diario Oficial de la Unión Europea*, L 2024/1689.
- Schuchter, A., & Levi, M. (2016). The Fraud Triangle revisited. *Security Journal*, 29, 107–121. <https://doi.org/10.1057/sj.2013.1>

- Shaw, E., & Sellers, L. (2015). Application of the critical-path method to evaluate insider risks. *Studies in Intelligence*, 59(2).
- Singh, M., Mehtre, B. M., & Sangeetha, S. (2022). User behavior based insider threat detection using a multi fuzzy classifier. *Multimedia Tools and Applications*, 81(16), 22953–22983. <https://doi.org/10.1007/s11042-022-12173-y>
- Soh, C., Yu, S., Narayanan, A., Duraisamy, S., & Chen, L. (2019). Employee profiling via aspect-based sentiment and network for insider threats detection. *Expert Systems with Applications*, 135, 351–361. <https://doi.org/10.1016/j.eswa.2019.05.043>
- Sollod, R. N., Wilson, J. P., & Monte, C. F. (2009). *Teorías de la personalidad: Debajo de la máscara* (1.^a ed. en español). McGraw-Hill.
- Taylor, M., Haggerty, J., Gresty, D., Almond, P., & Berry, T. (2014). Forensic investigation of social networking applications. *Network Security*, 2014(11), 9–16.
- Terrill, D., Trichas, M., & Bowden, D. (2024). “To betray, you must first belong”: Psychological pathways to insider threat and radicalisation. *Journal of Military and Strategic Studies*, 23(2).
- Tuor, A., Kaplan, S., Hutchinson, B., Nichols, N., & Robinson, S. (2017). Deep learning for unsupervised insider threat detection in structured cybersecurity data streams. *AI for Cyber Security Workshop (AAAI)*, 224–231.
- Van den Broeck, G., Lykov, A., Schleich, M., & Suciu, D. (2022). On the tractability of SHAP explanations. *Journal of Artificial Intelligence Research*, 74, 851–886.
- Wei, Z., Rauf, U., & Mohsen, F. (2024). E-Watcher: Insider threat monitoring and detection for enhanced security. *Annals of Telecommunications*, 79(11), 819–831. <https://doi.org/10.1007/s12243-024-01023-7>
- Yuan, S., & Wu, X. (2021). Deep learning for insider threat detection: Review, challenges and opportunities. *Computers & Security*, 104, 102221. <https://doi.org/10.1016/j.cose.2021.102221>